



INTROL: Einführendes Labor Sicherheit

Kursmaterial HS25 - 2025

Florian Wamser & Ron Porath, Hochschule Luzern

11. November 2025

INTROL: Einführendes Labor Sicherheit

Letzte Änderung: 11. November 2025

Begleitendes Kursmaterial des Moduls *INTROL* im Herbstsemester 2025 an der Hochschule Luzern.
Kursmaterial für einen Semesterkurs mit 14 Wochenstunden.



Dieses Skript wird während der Vorlesung angepasst und vervollständigt. Neue Kapitel und Übungen kommen im Verlauf der Vorlesung hinzu.

Autoren

Thomas Jösler: Initiale Version

Raphael Bolfig: Überarbeitung

Raphael Bolfig: WildFire Submission File-Tests entfernt

Nicolas Richner: QUIC-Protokoll-Kapitel überarbeitet

Nicolas Richner: Komplette Überarbeitung für PA-440

Nicolas Richner: Überarbeitung

Dr. Florian Wamser, florian.wamser@hslu.ch

Dr. Ron Porath, ron.porath@hslu.ch

Ideen zum Inhalt und initiales Feedback: Thomas Jösler, Peter Infanger

Ausgabe 2025

Erstmalige Durchführung im H21 (2021).

Studentische Angaben

Bitte tragen Sie im folgenden Feld ihren Namen und Informationen zu ihrem Team ein, falls Sie in einem Team arbeiten.

Team: *

Vorname 1: *

Nachname 1: *

Vorname 2: *

Nachname 2: *

Vorname 3: *

Nachname 3: *

* Je nach Teamgrösse müssen die Felder *Vor-* und *Nachname* in der entsprechenden Anzahl ausgefüllt werden.

Sonstige Angaben und Anmerkungen:

Inhaltsverzeichnis

1	Vorwort	3
1.1	Feedback	3
1.2	Legende	3
2	Labor 5: Firewall Advanced	5
3	Aufbau der Labor-Infrastruktur	8
3.1	Aufbau des Netzwerks	8
3.2	Aktivieren der Basiskonfiguration	9
4	Firewalling mit vollständiger Layer 7-Prüfung	12
4.1	Firewall konfigurieren	12
4.2	Stammzertifikat auf Windows-PC installieren	15
5	Malware Threat Analysis	24
5.1	Antivirus Threat Analysis	24
5.2	WildFire Cloud Submissions: Cloud-Lösung für Malware-Detektion	28
6	Authentication	33
6.1	Benutzer anlegen	33
6.2	Captive Portal aufschalten	33
6.2.1	DNS-Eintrag erstellen	36
6.2.2	Zertifikat für Captive Portal ausstellen	37
6.2.3	SSL/TLS Profile erstellen	38
6.2.4	Authentication Profile erstellen	38
6.2.5	Captive Portal konfigurieren	39
6.2.6	Authentication Enforcement	40
6.2.7	Authentication Policy Rule	40
6.2.8	User Identification aktivieren	41
6.2.9	Captive Portal auf Inside-Interface aufschalten	42
6.2.10	Captive Portal testen	44
7	Layer 7-Web-Filtering	46
7.1	URL-Blocking	46
7.2	URL-Blocking auf Nutzer-Basis	49
7.3	Application Filtering	52
8	Social Media Tracking	58
9	Aufräumen	62

10 Anhang A: Konfiguration vom Ende des Basics-Versuch auf FW laden	64
11 Anhang B: How QUIC Impacts Network Security	65

1 Vorwort

1.1 Feedback

Mit Ihrer Mithilfe kann die Qualität des Kurses laufend den Bedürfnissen angepasst und verbessert werden.

Sollte etwas in diesem Kurs nicht wie beschrieben funktionieren, melden Sie dies bitte direkt dem Lehrpersonal oder per E-Mail an Florian Wamser (florian.wamser@hslu.ch).

Bei Problemen wenden Sie sich bitte ebenfalls an das Lehrpersonal.

1.2 Legende

Wichtige Begriffe und Schlüsselwörter sind *kursiv* gedruckt.

Auffällige Unteraussagen im Text sind **fett** gedruckt.

Kommandozeilenbefehle werden durch separate Felder mit grauem Hintergrund hervorgehoben. Zu Beginn einer Zeile sind Kommandozeilenbefehle mit einem > oder \$ gekennzeichnet. Für Referenzierungen wird bei grösseren Blöcken eine Zeilennummer angegeben. Weder das Kommandozeilenzeichen noch die Zeilennummer ist Teil der Eingabe.

```
1 echo "Hello World!"  
2 exit
```

Skriptinhalte oder Inhalte von Konfigurationsdateien werden ebenfalls in separaten Feldern mit grauem Hintergrund angegeben.

```
#!/bin/bash  
echo "Hello, world!"  
echo the $# parameter did not destroy pygments syntax highlighting  
time find . -type f -exec ls -l {} \; | awk '{sum += $5} END {print sum  
}'
```



Anmerkungen und Informationen sind weiterführende Hinweise zu Befehlen oder zu der aktuellen Aufgabe. Sie gelten als ergänzender Hinweis, Notiz oder Hilfestellung.



Dringend beachten. Was hier steht, unbedingt merken oder ausführen. Oft müssen Befehle zwingend für den folgenden Aufgabenteil ausgeführt werden.



Weiterführende Literaturhinweise oder Links. Dies sind Informationen, die nicht zur Ausführung der Versuche benötigt werden, aber bekannt sein sollten.

2 Labor 5: Firewall Advanced

Zielsetzung

- Praktischer Umgang mit einer professionellen Next Generation-Firewall
- Kennenlernen von Firewalling mit vollständiger Layer 7-Prüfung
- Praktische Durchführung von Firewalling mit Malware Threat Analysis
- Firewalling mit Authentifizierung konfigurieren und anwenden
- Layer 7-Web-Filtering kennenlernen und anwenden können
- Social Media Tracking kennenlernen

Diese Laborübung soll den Studierenden den praktischen Einsatz der Funktionen einer NextGen-Firewall vermitteln. Dabei werden die Studierenden das praktisch Umgesetzte immer wieder mit den gelernten theoretischen Grundlagen verifizieren.

Szenario: Diese Laborübung behandelt verschiedene Funktionalitäten von NextGen-Firewalls. Die Grundkonfiguration entfällt, da sie Gegenstand eines früheren Laborversuchs ist.

In einem ersten Teil wird der verschlüsselte Netzwerkverkehr mittels Entschlüsselung aufgebrochen. Dies ist notwendig, damit die Firewall den Netzwerkverkehr im Detail prüfen kann. Anschliessend wird gezeigt, mit welchen Funktionen das Herunterladen von schädlicher Software verhindert werden kann. In einem zweiten Teil wird das Authentifizierungs-Feature untersucht und gezeigt, dass für verschiedene Nutzer verschiedene Zugriffsrechte, z.B. auf Webseiten, vergeben werden können. Als nächstes wird gezeigt, dass mit NextGen-Firewalls nicht nur Websites als Ganzes, sondern auch einzelne Funktionen davon auf feingranular Basis blockiert werden können. Abschliessend wird darauf hingewiesen, dass User Tracking heute allgegenwärtig ist und wie diesem mit Hilfe einer NextGen Firewall entgegengewirkt werden kann.

Benötigte Mittel / Materialien

Verwenden Sie für diesen Versuch die Labor-Arbeitsstationen. Jedes Labor-Team benötigt einen Labor-Doppelarbeitsplatz. Gesamthaft wird folgende Hardware benötigt.

- 2 Labor-PCs
- 1x Palo Alto PA-440 mit Netzteil
- Diverse LAN-Kabel



Bitte überprüfen Sie an Ihren Arbeitsplätzen sorgfältig, ob alte Einstellungen von vorherigen Übungen, wie beispielsweise der Proxy-Server unter Windows oder die Proxy-Einstellungen in den Browsern **Firefox** oder **Chrome**, **nicht** aktiviert sind. Es kommt häufig vor, dass Studierende die Einstellungen unter Windows vergessen zurückzusetzen.

1. Öffnen Sie die Windows-Einstellungen, indem Sie die Tastenkombination [Windows] + [I] verwenden. Dort klicken Sie dann auf **Network & internet**.
2. Wechseln Sie dann in die Kategorie **Proxy**. Im rechten Teil des Fenster deaktivieren Sie nun die Option **Automatically detect settings** oder **Einstellungen automatisch erkennen**.
3. Unter dem Punkt **Manual proxy setup** klicken Sie auf **Set up** und deaktivieren Sie die Option **Use a proxy server: Off**.

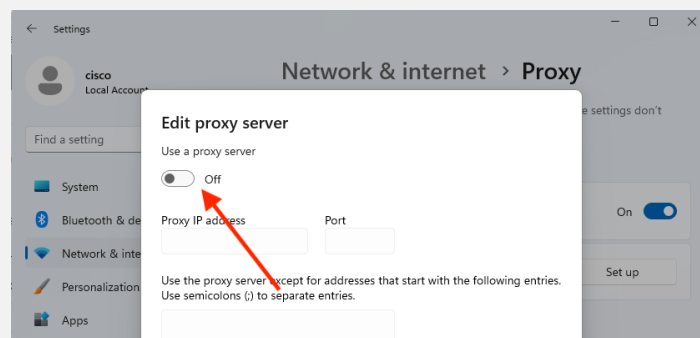


Abbildung 1: Deaktivieren der systemweiten Proxy-Einstellung unter Windows: **Use a proxy server: Off**.



4. Wechseln Sie zum **Mozilla Firefox**. Klicken Sie auf das Burger-Menü mit den drei horizontalen Strichen rechts neben der URL-Eingabemaske. Klicken Sie auf **Einstellungen** → **Allgemein** → **Verbindungs-Einstellungen** → **Einstellungen...**
Setzen Sie **Kein Proxy** oder **No proxy**.

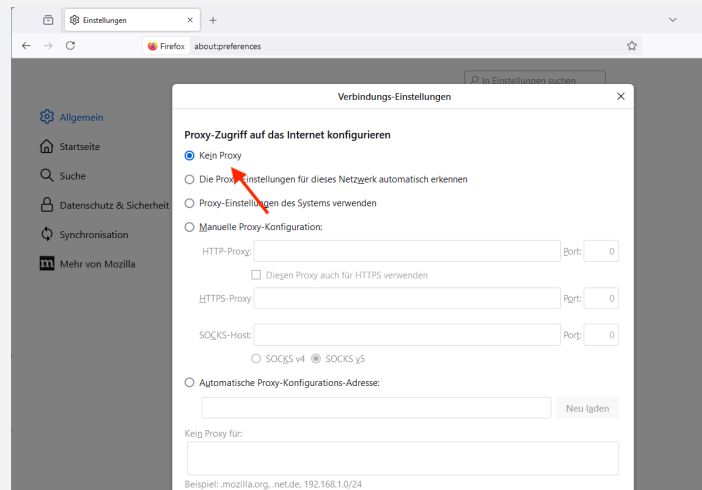


Abbildung 2: Deaktivieren der Proxy-Einstellung für den Browser **Mozilla Firefox**.

3 Aufbau der Labor-Infrastruktur

Dieses Kapitel beinhaltet alle Aufgaben, die ausgeführt werden müssen, bevor mit der eigentlichen Übung begonnen werden kann.

3.1 Aufbau des Netzwerks

1. Bauen Sie den Versuch entsprechend auf und verkabeln Sie Ihre Labor-PCs und die PA-440-Firewall entsprechend dem physischen Netzwerkdiagramm.

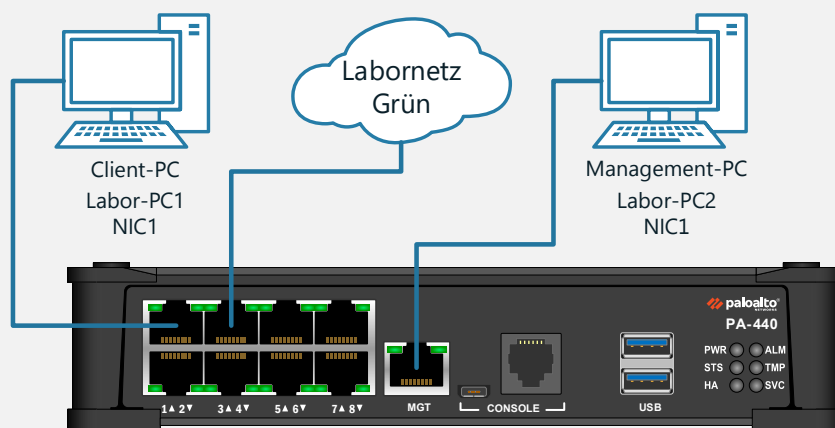


Abbildung 3: Netzwerkdiagramm - physische Sicht.

2. Konfigurieren Sie die IP-Adresseinstellungen der Labor-PCs gemäß folgendem Netzwerkdiagramm. Stellen Sie sicher, dass Sie verstehen, an welchen Stellen Sie DHCP einstellen oder IP-Adressen manuell konfigurieren müssen. Studieren Sie zudem die restlichen Informationen im Diagramm. Es gibt Auskunft über die Adresskonfigurationen und weitere Details des Aufbaus.

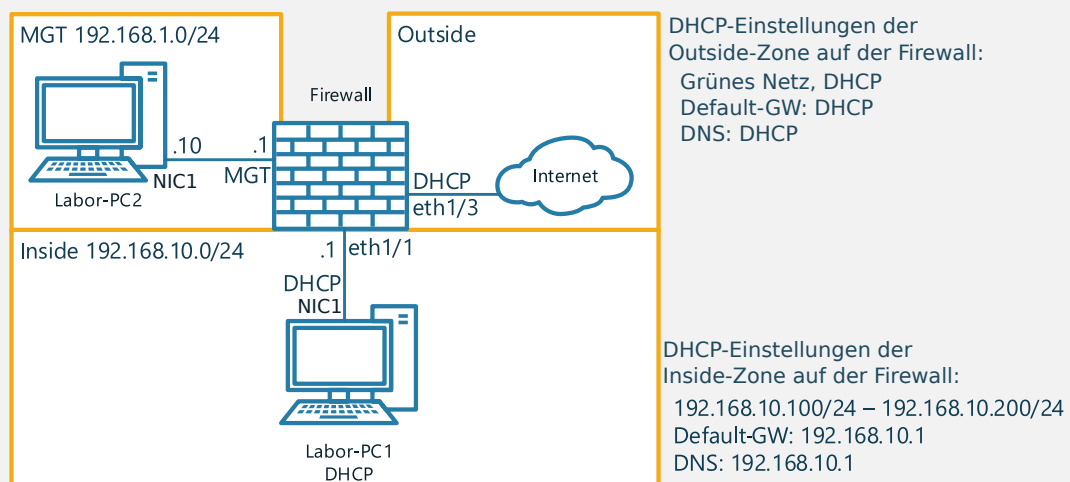


Abbildung 4: Netzwerkdiagramm - logische Sicht.

3.2 Aktivieren der Basiskonfiguration

Im **Firewall Basics**-Versuch haben Sie bereits eine Basiskonfiguration vorgenommen. Auf einer sehr ähnlichen Konfiguration wird in diesem Versuch aufgebaut.

1. Falls noch nicht geschehen, starten Sie die Firewall. Es dauert bis zu 5 min bis die Firewall gestartet ist. Warten Sie bis das **STS-LED** (= Status-LED) grün ist.
2. Loggen Sie sich vom Management-PC (Labor-PC2) auf Ihrer PA-440 ein: <https://192.168.1.1>. Der Benutzername ist **admin** und das Passwort ist **Hslu1234**.
3. Wechseln Sie in den **Device**-Tab, danach ins **Setup**-Menü und in den **Operations**-Tab. Mit **Load named configuration snapshot** kann eine auf dem Gerät abgespeicherte Konfiguration geladen werden. Wählen Sie die **advanced_start-config.xml**. Sollte die **advanced_start-config.xml** nicht auf Ihrer PA-440 vorhanden sein, gehen Sie bitte nach **Anhang 10 Konfiguration vom Ende des Basics-Versuch auf FW laden** vor und kehren Sie anschliessend hierher zurück.

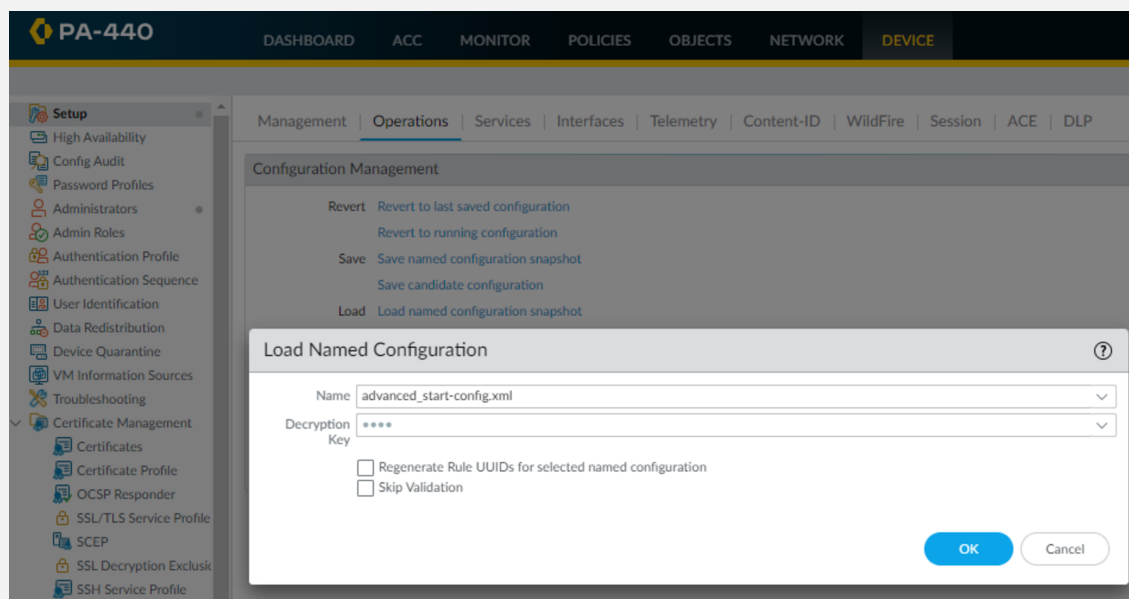


Abbildung 5: Startkonfiguration laden.

Es dauert nun ein paar wenige Sekunden, bis die Konfiguration geladen ist. Wie auch im **Basics**-Labor gelernt, müssen Änderungen zuerst per **Commit** aktiviert werden. Dies ist auch beim Laden der Konfiguration der Fall.

4. Commiten Sie nun die geladene Konfiguration. Sie können bereits weiterlesen, während die Änderungen committed werden.



Bitte überprüfen Sie das Datum und die Uhrzeit Ihrer Firewall und stellen Sie sicher, dass diese korrekt auf die aktuelle Zeitzone und Zeit eingestellt sind. Die entsprechenden Einstellungen finden Sie im Tab [Device](#) im Menü [Setup](#) unter [Management](#) → [General Settings](#). Klicken Sie auf das Zahnradsymbol, um die Einstellungen anzupassen. Wenn die Uhrzeit des Geräts nicht korrekt ist, können die nachfolgenden Übungsschritte fehlschlagen.

4 Firewalling mit vollständiger Layer 7-Prüfung

Die meisten erweiterten Funktionen einer NextGen-Firewall setzen voraus, dass der Datenverkehr bis zum OSI-Layer 7 mitgelesen werden kann. Andernfalls ist eine Auswertung des Datenverkehrs für die Firewall nicht möglich. Aus diesem Grund müssen verschlüsselte Verbindungen **abhörbar** gemacht werden. In diesem Kapitel konfigurieren Sie diese Funktion. Im Prinzip lässt sich das, was hier geschieht, mit einem Man-in-the-Middle-Angriff vergleichen. Bei beiden Methoden wird der Datenverkehr abgefangen, gelesen und weitergeleitet.

Vereinfacht sieht die Kommunikation zwischen zwei Endgeräten über eine Firewall, die Entschlüsselung durchführt, wie in Abbildung 6 aus. Jedes Endgerät baut eine verschlüsselte Verbindung zur Firewall statt zum anderen Endgerät auf. Dieser Sachverhalt ist jedoch bei den Geräten mit entsprechender Konfiguration nicht erkennbar.

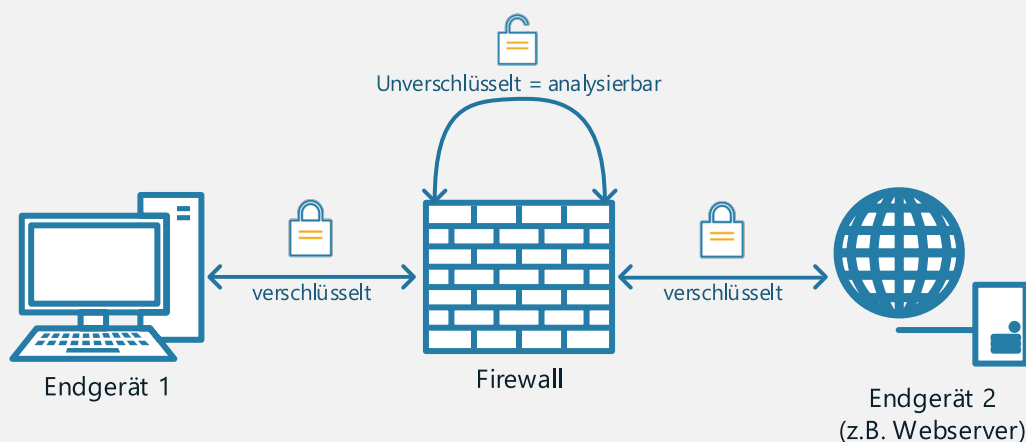


Abbildung 6: Verschlüsselte Verbindungen aufbrechen.

4.1 Firewall konfigurieren

1. Als erstes müssen wir ein Zertifikat erstellen, mit welchem wir die Ende-zu-Ende-Verbindungen verschlüsseln, um sie bei Bedarf entschlüsseln zu können. Navigieren Sie dazu in den **Device**-Tab und wählen Sie das **Certificates**-Menü. Generieren Sie mittels **Generate** in der Aktionsleiste am unteren Rand ein neues Zertifikat. Verwenden Sie die gleichen Angaben wie im Screenshot in Abbildung 7.

Generate Certificate ⓘ

Certificate Type ☒ Local ☐ SCEP

Certificate Name

Common Name
IP or FQDN to appear on the certificate

Signed By

☒ Certificate Authority
☐ Block Private Key Export

OCSP Responder

^ Cryptographic Settings

Algorithm

Number of Bits

Digest

Expiration (days)

^ Certificate Attributes

☐	TYPE	VALUE
--------------------------	------	-------

Abbildung 7: Certificate erstellen.



Hier wird ein Stammzertifikat erstellt von dem später weitere Zertifikate abgeleitet werden können. Es bedarf keiner externen Signatur für dieses Zertifikat, da es sich hier um ein Stammzertifikat handelt. Das Feld **Signed By** bleibt leer. Somit handelt es sich um ein **self-signed**-Zertifikat. Das Zertifikat selbst ist der Aussteller des Zertifikats und der öffentliche Schlüssel des Ausstellers ist im Zertifikat selbst enthalten. Die Einstellungen für den kryptographischen Algorithmus müssen “sehr hoch” für die Felder **Number of Bits** und **Digest** gesetzt werden, damit gängige Browser das Stammzertifikat akzeptieren.

2. Als nächstes muss das Zertifikat nochmals editiert werden. Wählen Sie dazu das Zertifikat aus und setzen Sie die drei noch nicht gesetzten Checkboxes. Damit deklarieren wir, dass das Zertifikat für das Wiederverschlüsseln verwendet werden kann.

Certificate information	
Name	myCACert
Subject	/CN=fw01.mydomain.ch
Issuer	/CN=fw01.mydomain.ch
Not Valid Before	Aug 16 06:46:48 2022 GMT
Not Valid After	Aug 16 06:46:48 2023 GMT
Algorithm	RSA
	☒ Certificate Authority
	☒ Forward Trust Certificate
	☒ Forward Untrust Certificate
	☒ Trusted Root CA

Abbildung 8: Forwarding mit diesem Certificate erlauben.

3. Nun aktivieren wir **Decryption**. Wechseln Sie dazu in den **Policies**-Tab und wählen Sie das **Decryption**-Menü.
4. Erstellen Sie hier eine neue Regel mit folgender Konfiguration. Bei den restlichen Optionen können die Default-Werte belassen werden.

Tabelle 1: Einstellungen für die neue Regel

Wert	Konfiguration
Name:	<i>beliebig</i>
Source:	Any (Zone/Address/User)
Destination:	Outside
Options - Action:	Decrypt (siehe <i>Radio Button</i>)
Options - Type:	ssl-forward-proxy

5. Wie immer müssen Änderungen mittels **Commit** aktiviert werden.

4.2 Stammzertifikat auf Windows-PC installieren

Öffnen Sie auf dem Client-PC (Labor-PC1) eine **Mozilla Firefox**-Instanz und navigieren Sie zu <https://www.hslu.ch>. Sie sehen, dass etwas noch nicht ganz stimmt.

Ihr Browser warnt Sie mit den Meldungen

- **Software is Preventing Firefox From Safely Connecting to This Site** oder
- **Warning: Potential Security Risk Ahead.**

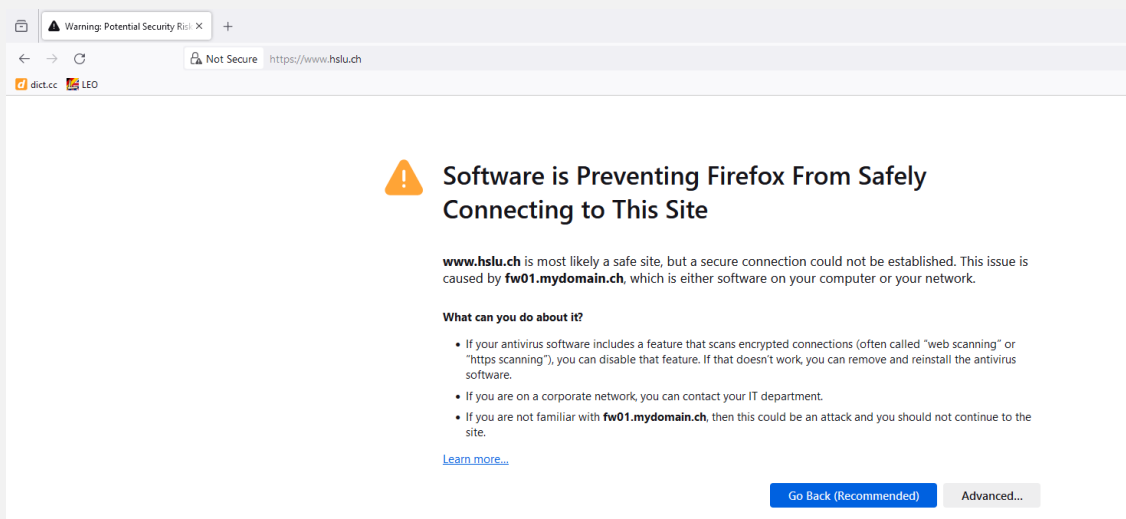


Abbildung 9: Warnung des Browsers aufgrund des Zertifikats für die Verbindung zu <https://www.hslu.ch>, das nicht von einer anerkannten Zertifizierungsstelle abstammt.



Das für die Verbindung zu <https://www.hslu.ch> verwendete Zertifikat ist nicht vertrauenswürdig, da es nicht von einer anerkannten Zertifizierungsstelle stammt. Dies ist auf die Firewall zurückzuführen, die das Zertifikat durch ein eigenes generiertes Zertifikat ersetzt hat, um den verschlüsselten Netzwerkverkehr abhören und untersuchen zu können.



Anmerkung: Die Firewalls von Palo Alto können den Datenverkehr entschlüsseln, damit Firewall-Filter-Regeln nach bestimmten Eigenschaften einstellbar sind oder um den Datenverkehr auf Bedrohungen zu überprüfen. Durch diese Entschlüsselung können Richtlinien für verschlüsselten Datenverkehr durchgesetzt werden, um sicherzustellen, dass bestimmte Inhalte trotz Verschlüsselung nicht übertragen werden können. Die Entschlüsselung des Datenverkehrs dient dazu, zu verhindern, dass schädliche verschlüsselte Inhalte in ein Netzwerk gelangen und dass sensible Informationen das Netzwerk nicht in verschlüsselter Form verlassen.



Falls Sie statt der oben genannten Meldungen die Fehlermeldung **Error code : SEC_ERROR_BAD_SIGNATURE** im **Mozilla Firefox** erhalten, führen Sie untenstehende Schritte aus:

*Es befinden sich noch alte Zertifikate im Zertifikatsspeicher, die ein Studierender vor Ihnen nicht gelöscht hat, siehe **Kapitel 9 Aufräumen**.*

1. Starten Sie mit **<WINDOWS-Taste>-r** das **Ausführen-Menü**.

Starten Sie den **Zertifikatsmanager** für **Current User** mit dem Befehl **certmgr.msc**.

Entfernen Sie die Zertifikate mit den Namen **fw01.mydomain.ch**, **hslu.ch** oder **www.hslu.ch** aus dem **Store Trusted Root Certification Authorities**, falls diese vorhanden sind.

2. Starten Sie mit **<WINDOWS-Taste>-r** das **Ausführen-Menü**.

Starten Sie den **Zertifikatsmanager** für **Local Computer** mit dem Befehl **certlm.msc**.

Entfernen Sie die Zertifikate mit den Namen **fw01.mydomain.ch**, **hslu.ch** oder **www.hslu.ch** aus dem **Store Trusted Root Certification Authorities**, falls diese vorhanden sind.

3. Starten Sie **Mozilla Firefox** neu.

→ Falls das Problem danach *nicht* gelöst ist, melden Sie sich bitte beim Laborpersonal bevor Sie fortfahren.

Wir werden nun das zuvor erstellte Stammzertifikat (**root certificate**) der Firewall von Hand auf unserem Labor-PC installieren. Für den professionellen Umgang mit Zertifikaten und für ein vertieftes Studium der Funktionsweise verweisen wir auf das **Information Security Labor**-Modul.

1. Akzeptieren Sie das Risiko in der Meldung des **Mozilla Firefox** in dem Sie auf **Advanced** und **Accept the Risk and Continue** klicken.

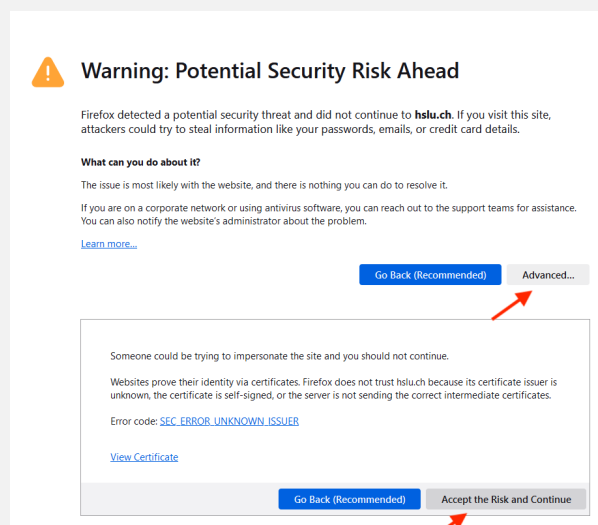


Abbildung 10: Webseiten-Ausnahme erstellen, um auf die Seite einmalig zugreifen zu können.

2. Klicken Sie auf das Schloss-Symbol mit dem Ausrufezeichen-Symbol in der Adressleiste des Browsers und wählen Sie **Connection not secure**. Klicken Sie auf **More information**.

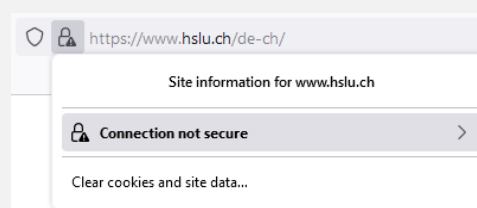


Abbildung 11: Zertifikatsfehler in **Mozilla Firefox**.

3. Klicken Sie auf den Button **View Certificate**.

4. Eine neue Seite öffnet sich im **Mozilla Firefox**. Suchen Sie den Abschnitt **Miscellaneous** und laden Sie sich die gesamte Zertifikatskette mit einem Klick auf **PEM (chain)** herunter.

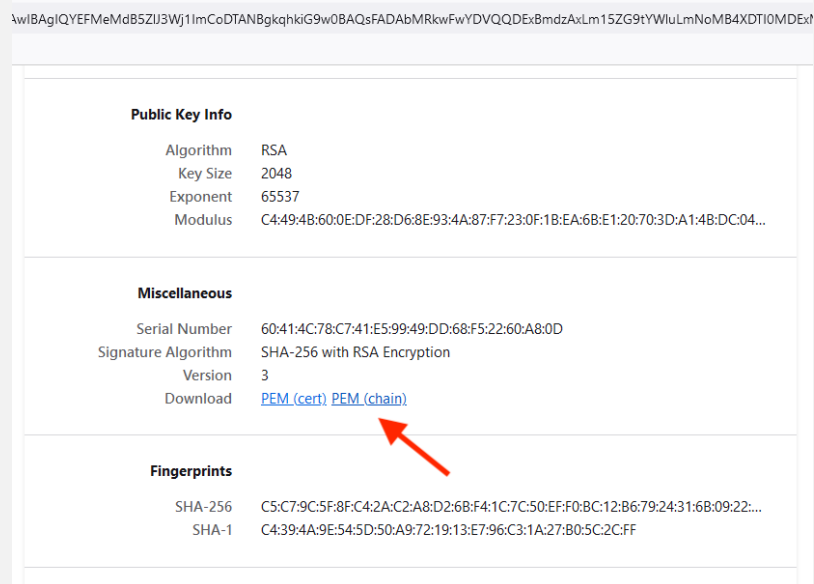


Abbildung 12: Downloaden der Zertifikatskette.

5. Benennen Sie die heruntergeladene Datei um. Geben Sie ihr die Endung **.cer**, damit wir nachher das Zertifikat bequem installieren können.

6. Öffnen Sie nun die heruntergeladene Datei in einem Editor, beispielsweise **Notepad** oder **Notepad++**.

```

C:\Users\cisco\Downloads\www-hslu-ch-chain(1).pem - Notepad++
File Edit Search View Encoding Language Settings Tools Macro Run Plugins Window ?
www-hslu-ch-chain(1).pem
1  -----BEGIN CERTIFICATE-----
2  MIIE0zCCArugAwIBAgIQYEFMeMdB5Z1J3Wj1ImCoDTANBgkqhkiG9w0BAQsFADAb
3  MRkwFwYDVQQDExBmdzAxLm15ZG9tYWluLmNoMB4XDTEOMDExMjAwMDAwMjAwMDTI1
4  MDIwNTIzNTk0VowVzELMAkGA1UEBhMCQ0gxdzANBgNVBACsTBkxlemVyb3EhMB8G
5  A1UEChMYSG9jaHNjaHVzSBMDXp1cm4gKEhTTTFUpMRQwEgYDVQQDEwt3d3cuahNs
6  dS5jaDCCASiWdQYJKoZIhvcNAQEBBQADggEPADCCAQoCggEBAMRJS2AO3yJWjPNK
7  h/cjDxvqa+EgcD2hS9wE/qH8PrzCGhXIW+0/jgvZogAbZODIPgB/ERG64fj0Bd7z
8  hFzPES1/fv/DGRcn9dfaClb6MYfHVKEvhc2j8EZcLa3dKWqH+Rp1lBK0yESomvGR
9  1vDH+GnpglUfKvAME+n8rMchx/dXVG818AxoHee72BnxIeq6+0fniGTf5K+1Ajqe
10  95HbinCNk/swh/HNqlWpvc2fvJYFaYsr5gvyBGNsfPHdZYnePPATIOSnk5G+eOq9
11  JStyt06adXiIg5UL1khZdNfxQptOBWrsQT/gd255fBwMxPshHV/ArB/eoMzu/yMv
12  zwJjEEsCAwEAaOB1jCB0zAdBgNVHQ4EFgQUPcmocRoEozsUTrr/vWKOHPf5sOhAw
13  dQYDVRORBG4wbIILd3d3LmhzbHUuY2iCB2hzbHUuY2iCEHByb2QtZ3d3LmhzbHUu
14  Y2iCDWFsdWluaWHzbHUuY2iCEXZ3dy5hbHVtbnloc2x1LmNogglpc2EtY2FtcHVz
15  LmNoghF3d3cuahNsLWNhbXB1cy5jaDAOBgNVHQ8BAf8EBAMCBAAwHQYDVRO1BBYw
16  FAyIKwYBBQUHAwEGCCsGAQUFBwMCAwGALUdEwEB/wQCMAAwDQYJKoZIhvcNAQEL
17  BQADggIBABj4LpSuBx75/0qx3s218ce9XKcMBXHNJ/6+fWJufzAYQVKyONC/+w05
18  ac39DksfnPJdptg7b7NaUvYmKwNQQRHkvetk4+EcZ4snPJXHYRE66qDt9czUASNX
19  DTkVdfTaZrpoKiETbRlP71RDW117mQtf7ymiQrtro5j9D1gkwcagMcs36yXhJJBh
20  drW2GS10/xop40zp38CQ/20x/7GiDtIGgfojyX5FbQmeQWbEBGgB2QgguW+bYAKT
21  MngXpOvkxd4rhpWRE41e1Vp4yevnKjKDQL/ykIf7kM4N6evYFwQXITatYOJye0Gu
22  XTW7QCKVOVBTLmNo1NBdR3h0Bof1Th0p40V3su+8dHmaiUnma9L4ETsKjt/Q3AD
23  Gywhj291cOMmMWARscXmgHDIsw7ZktLSvVH+olFedo/S+zfhBoIsGOUBpC1L2EB8
24  CD81qG7sfnn7N2KIImGwy2gfYocqY8o4x9M8dkmv3M3WoUwYwWmWuXpcWp1q1tLW
25  2+YahUJlMq6TKhV2upkuckj7Nbs0BLImRbSapCsGTFzHYPIOjF/X6NO/1bmYHNj
26  z1AcOsnWC3KelXFrbe6fmNWg0q7neZjGmlQ6Io2alhn7oI4k2kkqJkxxcn/deFqx
27  42koIqbDXiEl0DOy2IzFKKkYrpyC9j1rSBf9LevE8W4Ao9u1CH6Z
28  -----END CERTIFICATE-----
29  -----BEGIN CERTIFICATE-----
30  MIIE1jCCAr6gAwIBAgIJANohpyS5LSnCMAGCSqGSIb3DQEBAQUAMBSxGTAXBgNV
31  BAMTEGZ3MDEubXk1b21haW4uY2gwHhcNMjQwNTA2MTEwMTIyWWhcNMjUwNTA2MTEw
32  MTIyWjAbMRkwFwYDVQQDExBmdzAxLm15ZG9tYWluLmNoMIIICiJANBgkqhkiG9w0B
33  AQEFAAOCAg8AMIICCCgKCAgEAQWftBTuNCzUJijzRGjFiTslg29SFG3HwMDZ30rJe
34  0fYRayapFfDZwoiQC9ZqLPwR+N6Wz7QD+1Yq4MYjYXJvpd36Ebc8yh7JErYHfcBk
35  LjXSpGwxL/kmQdH2bLkhyb31Eg8vIs67LbwqApqB4nke480SAvt2+m1X2pIFkeIG
36  racR2UBXsCyFs4yHNwXMFvqLDSHw+j1XVnJmVZEAB1NnIGVrdLpJF080SzlqZY3
37  GQE9wFDPsDq4t/RXGUo1MI6DZM1tY5I0XbaCJTdkazTCH4ywxDM2I8Q+6Ber3XT
38  5u/e15J8wCwhoWj3kwy9Z2vROHvi6vT1Lvdd01FmUhesj2uf1L4JnyMbfbtMBP2
39  KNPa5ZKhGbcjOpIjPt1OZdzcnKvLGkAucX05/8vYKEkp521t8bCpQLT7+deLQ/
40  Ct6TUEo1bIapikGjB84vV+xxwGu4trTvgN4xGuuNQGA1QJ1zKIHB7kyK0M5Gnu
41  FGjQna+B7RRzsWfNRv+nQcJ2s2963m3WRA1RM3RcKzGYItDIqK9LkGUDPK1Tihx
42  F5j7mz6BXAbelGT8EYocOB6WW7ggLvGwCRgj4VHhe+D0GZJwmSoissbpd1OB9qb4
43  lCMeOChCsEkACbAula/fqTUGRP+/zi0X1GPMQSF0+QVr8hv+aAgw06qU2FFN+56u
44  VZOCawEAAaMdBswDAYDVROTBauAwEB/zALBgNVHQ8EBAMCAgQwDQYJKoZIhvcNAQ
45  AQENBQADggIBACCur9+MXW7r+Y4phB3cErBumvfqenqdd8Kiit2sNXWf00sME2vM
46  ou/UE1fyFOtAuTQJjztwOUlmoUZOx+NVC1e95EpQ8VggC7Ik5dcjZfOpTyAs4U+R
47  EnRCOIQhCLBLYsERcyif+iDsFgXvuUBdQwiqlJXiVbcTIulcjduZ/z14HNyQ6gAS
48  ElnalVsn01CApfuSoqNsM4pNvj3gkgSIGyFRTK2982Tiy9kyyjLitF2gLCqmPPQJ
49  kh7C2WEK5u3N6S/o79vqTinzkRFTd+NkjkFTKUEHNdWjTgb81CZydfpf+F3k+tJE
50  7E22g+tmknQ9k1UuDWnBdi45dwrqHB+e4+u9beqCN1c09D5sitGCLWUPQC9zpIOC
51  +hObFaHp20c6LFuqHiiWHD9b6UCMVqVs4487SpqlWvOLGtC/kcCtORuk01X9Lan
52  usNnjrQrsP+vpv//8rGGS/1FYHa+jtcjNPPbtUmnlzIRQVNBqKqybG6bjy4XctQ
53  8sc81IahOKcRNK9bTqA0RrODoQHb/LUaP69+QdcKq93xPANonkOH1IZIxlvnp5J0
54  rtr1R51rC1+TUYK78Y2jua03x6q5RngFUOPBMPISY1TO8ORvrtRPCJZdZSDiJm
55  tuUI8Fmt4SNMeMBQBi3RquQ2JbKvnm1lB1RAM6QDCGctiIRK+W15iwyX
56  -----END CERTIFICATE-----

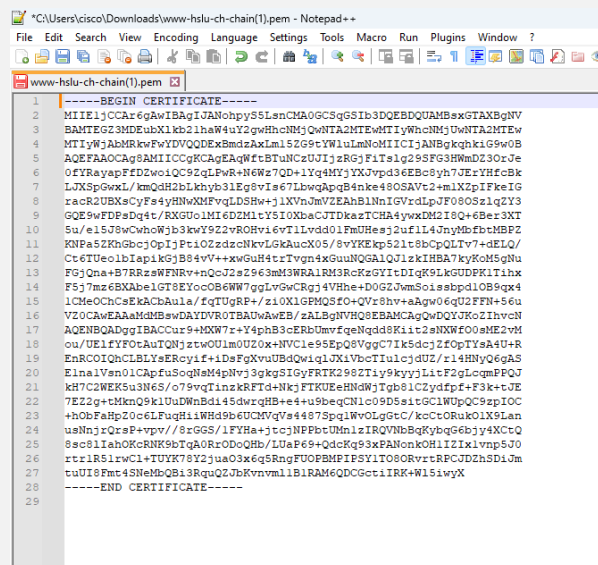
```

Abbildung 13: Zertifikatsdatei im **Notepad++**.

7. Sie sehen nun zwei Zertifikate. Die Zertifikate beginnen jeweils mit der Zeichenkette
-----BEGIN CERTIFICATE-----.

8. Das erste Zertifikat ist das Zertifikat für die Webseite <https://www.hslu.ch>. Dieses benötigen wir nicht. Das zweite Zertifikat ist das Stammzertifikat der Zertifizierungsstelle, das wir installieren möchten.

Löschen Sie das komplette *erste* Zertifikat von -----BEGIN CERTIFICATE----- bis -----END CERTIFICATE----- . Speichern Sie die Datei ab, sodass nur noch das zweite Zertifikat enthalten ist.



```

1  -----BEGIN CERTIFICATE-----
2  MIIEIjCCAg6gAwIBAgIUAhNohpyS51LenCMA0GCSqGSIb3DQEBAQUAAwQTAxIB
3  BAMTEG23MDEubW1kb21haW4uY2gwHhcnMjQwNTA2MTEwMTYwbnMjQwNTA2MTEw
4  MTYwYjA0MRkwFwYDVQQDExBmdzZAxLm15ZG9tYXN0MIICjANBgkqhkiG9w0B
5  AQEFAAOCAg8AMIICcCqKCAgEAgWftBTuNCzUJIjzRGjFAts1q2SFG3HmDZ30rJe
6  OfYRayapFEDZwo1QC9ZqLPwR+N6Wz7QD+1Yq4MYjYXJvpd36EB08yh7JErYHfcBk
7  LUXSpGwxL/kmQdH2bLkhyb31Eg8vIs67LbwqApqB4nke480SAVt2+m1XZpIFkeIG
8  racR2UBXsCyFs4yHhWXMfVqLDSHw+j1XVnJmVZEAb1NnIGVrdLpJF080SzlqZY3
9  GQ9wFDFsDq4t/RXGUo1MI6DZM1tY5IOXbaCJTDkazTCHAA4ywxDM218Q+6Ber3XT
10 Su/e15J9wCwnoJb3kwY9Z2vROHv16vT1Lvd01FmUhesj2uF1L40nyMbfbtMBFZ
11 RNBa5ZKhGbcjOpIjPc1OZdzcnKvLkAucX05/8vYKEKp521t8bCpQLTv7+deLQ/
12 Ct6TDeolB1sp1kGjB84vV+xxwGuH4tzTvg4kGuuHQGA1QJ1zkiHBA7kyKcM5gWu
13 FGjQna+B7RRzeWFRv+nQcJ2aZ963mM3WRALRM3RcKaGvITdIqK9LkGUDPK1Ihx
14 F5j7mz6BXAbelGT8EYocOB6WV7gGwCrqj4VHhe+D0GZJwmSo1sabpd1OB9qx4
15 lCMeOChCsEkaChAula/fqTUGRP+/z10X1GPMQSF0+QVr8hv+aaGw06qU2FFN+56u
16 VZ0CawEAAAMdMBawDAYDVROTBAAUwAwEB/zALBgNVHQ8EBAMCAgQwDQYJKoZIhvcN
17 AQENBQADggIBACCuR9+HXW7r+Y4phB3cERbUmvfgeNqdd8K1t2nXKWf00aME2vM
18 ou/UE1fYFOtAuTQNJztwOU1m0U20x+NVC1e95EpQ8VggC7Ik5dcjZfOpTysA4U+R
19 EnRCOIqChCLBLyERoy1f+1DeFgXvuUBdQw1q1JX1VbctIu1cjdUz/z14HNyQ6gA5
20 Elna1Vsm01CkgFu5oGhM4pNvj3gkgS1GyFRKZ99Z1y9KyyjLatE2gLCqmPFQJ
21 KH7C2WEK5u3W65/079wq1nzKRFtd+NkjPTKUEeHk4WjTgb91CZydfpf+P3k+JE
22 7E2Zg+tmKnQ8klUuDNbD145dwrqHB+e4+uSbeqCN1c09D5aitGCLWUPQC9zpIOC
23 +hObFaHpZ0c6LFuqH1iWHD9b6UCMVHB+4487Spq1WvOLgGtC/koCtORuk0IX9Lan
24 u8NnjrQrsP+vpw//8rGGS/1FYHa+jtcjNFPbtUMn1zIRQVNBqKybq66bjy4XCtQ
25 8sc81IahOKcRNR9bTQA0RrODoQHb/LUAf69+QdcKq93xPANonkOH11Z1xlvnp5J0
26 rtt1R51rwC1+TUYK78Y2jua03x6q5RngFUOPBMPFISV1T080RvrtRfCJD2hSD1Jm
27 tuU18Fmr4SNeMbQB13RquQ2JbRvnmvml1B1RAM6QDGCtiIRK+W15iwyX
28 -----END CERTIFICATE-----
29

```

Abbildung 14: Die editierte Datei.

9. Wechseln Sie nun in den Ordner und installieren Sie das Zertifikat mittels dem Kontextmenüeintrag **Install Certificate**.

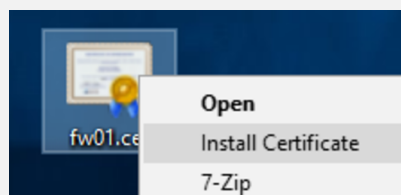


Abbildung 15: Install Certificate.

10. Wählen Sie **Current User** als **Store Location**.

11. Auf der folgenden Seite muss das Zertifikat in den **Trusted Root Certification Authorities**-Zertifizierungsspeicher abgelegt werden. Diesen finden Sie nach einem Klick auf **Next** unter dem Punkt **Place all certificates in the following store**. Aktivieren Sie **Place all certificates in the following store** und klicken Sie auf den Button **Browse...**

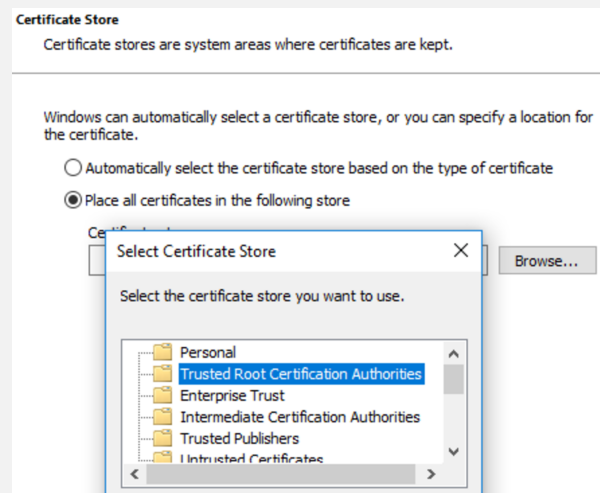


Abbildung 16: Certificate Store.

12. Navigieren Sie weiter durch den Dialog bis der Import abgeschlossen ist. Am Schluss werden Sie nochmals gefragt, ob Sie dieses Zertifikat wirklich importieren wollen. Bejahen Sie dies.
13. Starten Sie Ihren **Mozilla Firefox** neu und versuchen Sie erneut, die HSLU-Webseite <https://www.hslu.ch> zu öffnen.

14. Wenn alles funktioniert hat, wird die Webseite wie gewohnt und ohne Warnmeldung angezeigt. Es wird lediglich der Hinweis gegeben, dass Mozilla den Aussteller des Stammzertifikats nicht kennt.

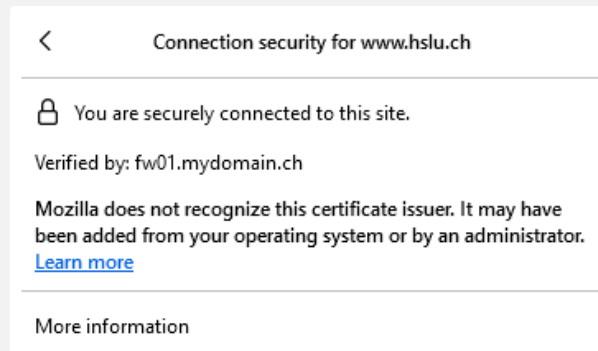


Abbildung 17: Zertifikatsmeldung vom **Mozilla Firefox**, wenn das Stammzertifikat zwar bekannt und akzeptiert ist, aber von einer “unüblichen” Zertifizierungsstelle abstammt.

Überprüfen und wiederholen Sie die letzten Schritte, falls weiterhin eine Zertifikatsfehlermeldung wie in **Abbildung 9** auftritt.



Eine funktionierende Entschlüsselung ist Voraussetzung für die korrekte Arbeitsweise der nächsten Teile dieser Laborübung.

5 Malware Threat Analysis

In diesem Kapitel werden zwei Mechanismen des Palo Alto-Betriebssystems zur Malware-Analyse und -Abwehr gezeigt.

5.1 Antivirus Threat Analysis

Grundsätzlich bietet die Antiviren-Bedrohungsanalysefunktion (Englisch für **Antivirus Threat Analysis**) keine neuen Funktionalitäten. Antivirenprogramme prüfen seit Jahrzehnten Dateisignaturen anhand von Listen bekannter Viren-Signaturen. Der Unterschied besteht hier jedoch darin, dass die Daten *gerade versendet* werden und durch die Firewall hindurchfliessen. Ähnlich wie bei clientbasierter Antivirensoftware müssen auch die Virensignaturen der Palo Alto-Firewall häufig und regelmässig aktualisiert werden. Im Folgenden wird gezeigt, wie die Funktion konfiguriert und getestet werden kann.

Um einen Vorher-Nachher-Vergleich durchführen zu können, laden wir zunächst eine Viren-Testdatei herunter. Das Europäische Institut für Computer-Antivirenforschung (EICAR) hat eine Datei zum Testen von Antivirensoftware entwickelt. Diese Datei enthält die folgende Zeichenfolge, die von Herstellern von Antivirensoftware als Virus erkannt wird, an sich aber nicht gefährlich ist.

```
X50!P%@AP[4\PZX54(P^)7CC)7}$EICAR-STDARD-ANTIVIRUS-TEST-FILE!$H+H*
```

Führen Sie folgende Schritte auf Ihrem Labor-PC1 (Client-PC) in der Zone **Inside** aus.

1. Öffnen Sie eine PowerShell-Konsole als Administrator und führen Sie folgenden Befehl aus.

```
> wget "https://secure.eicar.org/eicar.com" -OutFile C:\Temp\
    eicar.com
```

Dieser Befehl lädt die angegebene Ressource über das HTTPS-Protokoll in den angegebenen Pfad herunter und speichert sie unter **C:\Temp**.

2. Öffnen Sie nun einen Datei-Explorer und navigieren Sie zu **C:\Temp**. Versuchen Sie die Datei auszuführen. Was passiert? Warum ist das so?

Datei wird nicht ausgeführt, da sie von **Microsoft Defender** als Virus erkannt und automatisch gelöscht wird.

Palo Alto und sein Anti-Viren-Team haben bereits einige Vorarbeit geleistet. Palo Alto bringt

von Haus aus bereits ein **Default Antivirus Profile** mit. Dieses reicht uns für unsere Testzwecke. Zudem hat das HSLU-Team Ihre Firewall bereits mit einer Virensignatur-Datenbank ausgerüstet. Diese ist zwar nicht tagesaktuell, reicht aber für unseren Zweck.

3. Navigieren Sie in den **Policies**-Tab und wählen Sie das **Security**-Menü. Hier haben Sie im **Basics**-Versuch schon einige Regeln erstellt. Auf diesen bauen wir nun auf.

Editieren Sie die bestehende Security Rule, welche allen Traffic von **Inside** nach **Outside** zulässt. Wechseln Sie in den **Actions**-Tab, wählen Sie als **Profile Type** → **Profiles** aus und wählen Sie anschliessend als Antivirus-Profil **default** aus.

The screenshot shows the 'Security Policy Rule' configuration page with the 'Actions' tab selected. The 'Action Setting' section has 'Action' set to 'Allow' and 'Send ICMP Unreachable' unchecked. The 'Profile Setting' section has 'Profile Type' set to 'Profiles', 'Antivirus' set to 'default', and 'Vulnerability Protection' set to 'None'. The 'Log Setting' section has 'Log at Session Start' unchecked, 'Log at Session End' checked, and 'Log Forwarding' set to 'None'. The 'Other Settings' section has 'Schedule' and 'QoS Marking' both set to 'None'.

Abbildung 18: Antivirus Profile aktivieren.

4. Auch hier ist wieder ein **Commit** notwendig, um dieses Feature zu aktivieren.



Sie erhalten womöglich die Meldung, dass das Antivirus-Paket nicht aktuell ist. Sie können diese Meldung ignorieren.

```
> Warning: No valid Antivirus content package exists  
(Module: device)
```


5. Welcher Netzwerkverkehr sollte nun nach Ihrer Meinung vom Antivirus Filtering untersucht werden? Bewerten Sie untenstehende Statements mit Begründung!

Inside → Outside: _____

DMZ → Outside: _____

Outside → DMZ: _____

Outside → Inside:

Generell gilt, es sollte jeder Verkehr untersucht werden. Das einzige Argument gegen Virenschans sind mögliche Leistungseinbussen.

- **Inside → Outside**: Der Netzwerkverkehr zwischen internen Netzwerken und externen Netzwerken stellt oft das grösste Risiko für Malware-Infektionen dar.
- **DMZ → Outside**: Die DMZ fungiert oft als Schnittstelle zwischen dem internen Netzwerk und dem Internet und stellt somit ein hohes Risiko für Angriffe dar.
- **Outside → DMZ**: Ja, da auch der Verkehr von aussen in die DMZ überwacht werden sollte, um potenzielle Angriffe zu erkennen und abzuwehren.
- **Outside → Inside**: Ja, da der Verkehr von externen Netzwerken in das interne Netzwerk ein hohes Risiko für Malware-Infektionen darstellt.

Hinweis: Mit den aktuellen Einstellungen wird nur der **Inside → Outside**-Traffic vom AV-Filter geprüft.

Anmerkung: Es ist eine stateful-Firewall. Daher macht die Regel **Outside → Inside** eigentlich keinen Sinn, wenn zuvor schon eine Regel **Inside → Outside** vorhanden ist und wenn nicht explizit Verkehr vom Internet nach innen zugelassen werden soll (was normalerweise ja nicht der Fall ist). Daher könnte man hier auch argumentieren, dass für die letzte Regel der Virenschann unnötig ist, da die Regel nicht genutzt wird.

6. Versuchen Sie nun erneut die Malware-Testdatei herunterzuladen. Sie sollten nun eine Fehlermeldung beim `wget`-Befehl erhalten, der durch die Firewall ausgelöst wird.

```
> wget "https://secure.eicar.org/eicar.com" -OutFile C:\Temp\
    eicar.com
```

Abbildung 19: Blockiertes Herunterladen nach dem Einrichten der Firewall-Regeln für Antivirus-Detektion.

7. Wechseln Sie in den **Monitor**-Tab und öffnen Sie das **Threat**-Menü. Studieren Sie die Einträge, die generiert wurden. Achten Sie auf die **Receive Time**, falls es mehrere Einträge hat. Schauen Sie sich die aktuellen Einträge an. Die Details können Sie mit dem Lupen-Symbol öffnen.
8. Was könnte die angewandte Action **reset-server** im Zusammenhang mit dem verbindungsorientierten Protokoll HTTP (TCP/80) bedeuten? Was ist in diesem Fall passiert?

Die Verbindung zum Server wurde *von der Firewall* abgebrochen, damit der «Virus» nicht heruntergeladen werden kann. Die Firewall sendet ein **TCP RST**, um die Verbindung abubrechen. Somit ist die Verbindung auf TCP-Layer zwischen den Endpunkten resettet und muss neu gestartet werden. Es werden keine Daten übertragen. Ein Reset-Paket ist einfach eines ohne Nutzlast und mit gesetztem RST-Bit in den TCP-Header-Flags. Siehe auch <https://docs.paloaltonetworks.com/pan-os/9-1/pan-os-web-interface-help/objects/objects-security-profiles/actions-in-security-profiles>.

5.2 WildFire Cloud Submissions: Cloud-Lösung für Malware-Detektion

Palo Alto beschreibt sein **WildFire**-Feature mit folgenden Worten:

“Palo Alto Networks® WildFire® cloud-based threat analysis service is the industry’s most advanced analysis and prevention engine for highly evasive zero-day exploits and malware. The service employs a unique multi-technique approach combining dynamic and static analysis, innovative machine learning techniques, and a groundbreaking bare metal analysis environment to detect and prevent even the most evasive threats.”

Quelle: <https://www.paloaltonetworks.com/resources/datasheets/wildfire>

Kurz auf Deutsch zusammengefasst: **WildFires** cloudbasierte Threat-Analyse ist industrieführend und deckt alle Marketing-Schlagwörter, die zurzeit gängig sind, ab.

Das Datasheet¹ zu **WildFire** gibt schon etwas mehr Details preis. Darin wird erklärt, dass eine zu scannende Datei in einer geschützten Umgebung ausgeführt wird und verschiedene Technologien verwendet werden, um zu bewerten, ob die Aktionen der Datei denen von Malware ähneln oder nicht. Falls ein User eine bis dato unbekannte Malware in die **WildFire Cloud** hochlädt und diese als solche erkannt wird, profitieren sofort alle Nutzer der **WildFire Cloud** davon. Das System lernt kundenübergreifend neue Bedrohungen kennen und kann diese bekämpfen.

¹ Das Datasheet zu **WildFire** kann unter folgender URL heruntergeladen werden:
<https://www.paloaltonetworks.de/resources/datasheets/wildfire>

1. Navigieren Sie in den **Objects**-Tab und wählen Sie das **WildFire Analysis**-Menü unter dem Punkt **Security Profiles**. Klicken Sie unten auf **Add** und studieren Sie welche **File Types** und **Applications** mit **WildFire** überprüft werden können.
2. Beschreiben Sie, welche **WildFire Analysis**-Konfigurationen Sie in diesem Dialogfeld festlegen können.

Applications: Alle Cloud-Dienste werden aufgelistet.

File Types: Verschiedene executables, archives und andere Filetypen. Folgende File Types können analysiert werden: apk, archive, email-link, flash, jar, linux, MacOSX, ms-office, pdf, pe, script.

3. Schliessen Sie das Fenster wieder ohne zu speichern. Auch hier reicht für unseren Zweck die **WildFire Analysis**-Default-Konfiguration. Diese ist bereits von Haus aus dabei.
4. Das WildFire-Feature muss wie schon die **Antivirus Threat Analysis** zuerst auf eine **Security Rule** angewandt werden.

Navigieren Sie wieder in den **Policies**-Tab und wählen Sie das **Security**-Menü. Editieren Sie wie schon zuvor die **inside-outside-allow**-Regel. Wählen Sie im **WildFire Analysis**-Dropdown-Menü das **default**-Profil aus, analog zum Antivirus-Profil.

Abbildung 20: Aktivierung des **WildFire Analysis**-Profils.

5. Auch hier ist ein **Commit** nötig. Warten Sie, bis die Änderungen geschrieben wurden.
6. Laden Sie nun vom Client-PC (Labor-PC1) das von Palo Alto bereitgestellte **WildFire Test-File** herunter: <http://wildfire.paloaltonetworks.com/publicapi/test/pe>. Nutzen Sie wiederum den **Mozilla Firefox**.



Es dauert seine Zeit, bis die **WildFire Cloud** die Datei analysiert hat und ein Resultat liefert. Weiter unten finden Sie die Ergebnisse zum Download. Wir werden später mit den bereitgestellten Ergebnissen weiterarbeiten. Beantworten Sie in der Zwischenzeit die folgenden Fragen und lesen Sie im Text weiter, als hätten Sie die Ergebnisse auf der Firewall erhalten.

7. Navigieren Sie nun in den **Monitoring**-Tab und wählen Sie das **WildFire Submissions**-Menü. Hier erscheint der Report, sobald dieser verfügbar ist.

RECEIVE TIME	FILE NAME	URL	SOURCE ZONE	DESTINA- ZONE	SOURCE ADDRESS	SOURCE USER	SOURCE DYNAMIC ADDRESS GROUP	DESTINATION ADDRESS	DESTINATION DYNAMIC ADDRESS GROUP	DYNAMIC USER GROUP	DEST- PORT	APPLICATION	RULE	VERDICT	ACTION	SEVERITY
11/15 17:04:42	wildfire-test-apk...		inside	outside	192.168.10.100			35.204.106.198			80	web-browsing	inside-outside-allow	malicious	allow	High
11/15 17:02:42	wildfire-test-ge...		inside	outside	192.168.10.100			35.204.106.198			80	web-browsing	inside-outside-allow	malicious	allow	High
11/15 16:38:43	wildfire-test-go-file...		inside	outside	192.168.10.100			35.204.106.198			80	web-browsing	inside-outside-allow	malicious	allow	High

Abbildung 21: **WildFire Submissions**-Liste im **Monitoring**-Tab.

8. Sie haben das **WildFire Test-File** nun bei sich heruntergeladen. Niemand hat Sie am Download dieser potenziell schädlichen Software gehindert. Was bedeutet dies für die Funktionsweise der WildFire Cloud Solution in Anbetracht, dass Sie das Resultat, ob Malware oder nicht, erst in einigen Minuten erhalten?

Dies ist tatsächlich eigentlich ein Problem. Man wird erst im Nachhinein von der Firewall benachrichtigt. Dies liegt daran, dass die Tests einige Zeit dauern und dass ansonsten der Verkehr oft sehr lange blockiert werden würde - eben bis die Cloud die Daten in verschiedenen VMs getestet hat. Erst, wenn die Daten als schädlich erkannt wurden, werden zukünftige Downloads unterbrochen. Da die Signatur dann aber bekannt ist, gilt dies für alle Teilnehmenden der Wildfire-Cloud - weltweit. Der Vorteil hier ist zudem, dass durch die Analyse des Resultats in den VMs auch unbekannte Viren erkannt werden, weil sie durch ihr schädliches Verhalten aufgefallen sind.

9. Warum ist dieses Feature trotzdem nützlich?

Hinweis: Lesen Sie nochmals den einleitenden Text dieses Kapitels.

Dieses Feature ist sehr nützlich. Man profitiert durch das Teilnehmen an WildFire von einer globalen Liste an potentiellen Schadprogrammen, die geblockt werden können ohne im System vorhanden gewesen zu sein. Da die Signatur dann bei Palo Alto bekannt ist, gilt dies für alle Teilnehmenden der Wildfire-Cloud.

10. Gehen Sie auf einem beliebigen PC mit Internet zur folgenden URL, um einen echten Erkennungsbericht der Test-Malware zu erhalten, die Sie gerade zuvor heruntergeladen haben. Aus Zeitgründen haben wir die Berichte vorab heruntergeladen und stellen diese Ihnen zur Verfügung: <https://drive.switch.ch/index.php/s/rIOVWv0XgsaqbLd>.

Was können Sie aus dem Report herauslesen? Unter welchen Bedingungen wurde die potentielle Malware geprüft? Warum wurde von WildFire entschieden, dass es sich dabei um eine Schadsoftware handelt?

Hinweis: Prüfen Sie beide **WildFire Analysis Report**-Dateien und vergleichen Sie die Auswertungen. Beide Dateien gehören zu einem einzigen Analyse-Vorgang.

Man sieht auf dem Report die Herkunftsdaten, Download-Uhrzeit und um was für eine Datei es sich handelt. Sie wurde von zwei VMs ausgeführt und getestet, einmal auf Windows 7 und einmal auf Windows 10. Auf Windows 7 hat das Programm Dateien verändert und einen Registry-Eintrag geändert, deshalb wurde es gekennzeichnet. Bei Windows 10 nicht. Anhand des Verhaltens bei der Ausführung (in der VM/Sandbox) kann WildFire entscheiden, dass es sich um Malware handelt.

The screenshot shows the Palo Alto Networks WildFire portal interface. At the top, there's a navigation bar with 'Dashboard', 'Reports', 'Upload Sample', 'Settings', 'Account', and a user dropdown 'Wamser, Florian'. Below this is a 'REPORTS' section with a search bar 'Search by file name or sha256', dropdowns for 'Source' (Any) and 'Verdict' (Any), and 'Reset' and 'Search' buttons. A yellow box contains search tips: 'URL search doesn't support wildcards.', 'To make sure you receive intended results, please use the beginning of the URL without "http://". The search will work similarly to "starts with" function. For example, searching for "www.google.com/"<sub>">: "www.google.com" and "www.g" will work, "http://www.google.com" and "google.com" won't work.', and 'Note: depending on how it was submitted, not every URL will start with "www."'. Below this is a table of reports with columns: Received Time, Upload Source, Source IP, File / URL, Verdict, Recipient User ID, and Source Zone. One report is visible: Received Time: 2023-02-21 08:31:58, Upload Source: 021201037438, Source IP: 35.204.106.198, File / URL: wildfire.paloaltonetworks.com/publicapi/test/pe, Verdict: Malware, Recipient User ID: testuser, Source Zone: (empty). At the bottom, there's a footer with copyright information and links for Privacy, Contact Us, Search, and Terms of Use.

Received Time	Upload Source	Source IP	File / URL	Verdict	Recipient User ID	Source Zone
2023-02-21 08:31:58	021201037438	35.204.106.198	wildfire.paloaltonetworks.com/publicapi/test/pe	Malware	testuser	

Abbildung 22: Screenshot des WildFire-Portals mit erkannter Malware.

6 Authentication

Durch die *Authentifizierung* wird überprüft, wer der Benutzer ist. Die *Autorisierung* bestimmt, auf welche Ressourcen ein Benutzer zugreifen kann. Authentifizierung und Autorisierung werden heutzutage oft kombiniert. Auch in dieser Übung wird unter dem Begriff *Authentication* die Authentifizierung und Autorisierung in Kombination verstanden. In unserer Übung authentifizieren wir den Benutzer beim Netzwerk-Zugriff mittels eines *Captive Portal*. So können wir (schädliches) Verhalten einem Benutzer zuordnen oder auch verschiedene Zugriffsberechtigungen auf Nutzer-Basis vergeben.

6.1 Benutzer anlegen

Damit man sich Authentifizieren kann muss man entweder etwas haben (z.B. Google Authenticator), etwas sein (z.B. Fingerabdruck) oder etwas wissen (Username/Passwort). Wir entscheiden uns für die letzte Variante.

1. Navigieren Sie in den *Device*-Tab und wählen Sie das *Users*-Menü unter *Local User Database*. Erstellen Sie einen neuen Benutzer mit beliebigem Passwort. Notieren Sie sich das Passwort.



Beachten Sie, dass bei den Benutzernamen die Gross-/Kleinschreibung beachtet werden muss!

6.2 Captive Portal aufschalten

Um die Benutzer zur Authentifizierung zu zwingen, werden wir ein *Captive Portal* aufschalten. Auf diesem Captive Portal muss sich der Nutzer zuerst authentifizieren, bevor er ins Internet gelangen kann. Sie kennen diese Captive Portals sehr wahrscheinlich bereits aus Hotels oder Flughäfen.

Das *Palo Alto Captive Portal*-Feature ist einigermaßen komplex und bedarf vieler einzelner, zusammenhängender Komponenten, damit es funktioniert. Abbildung 23 erklärt, welche Elemente in diesem Kapitel konfiguriert und wie miteinander verlinkt werden. Die grün hinterlegten Elemente bestehen bereits als Default-Konfiguration oder sind Teil des Systems und müssen nicht neu erfasst/erstellt werden. Jedoch müssen diese Elemente entsprechend verlinkt werden.

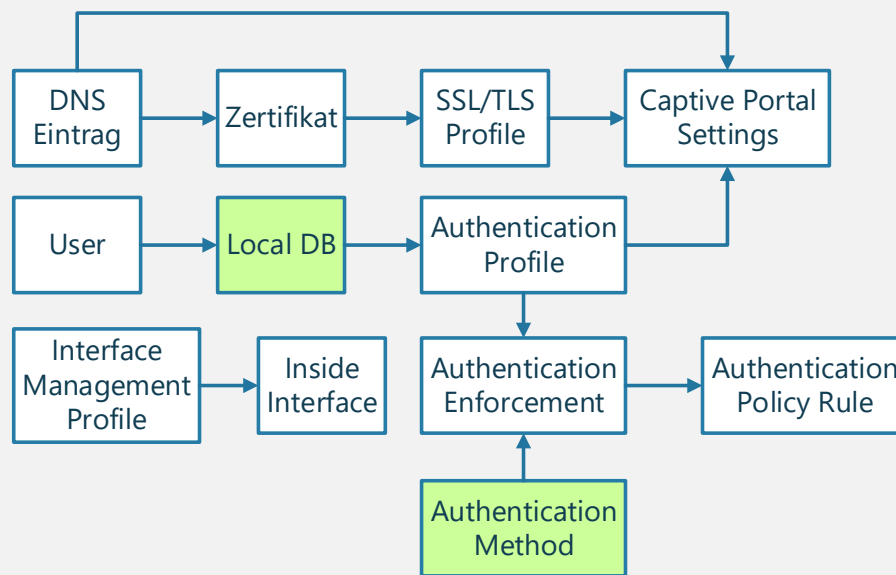


Abbildung 23: Zusammenhang Konfigurationselemente.

Folgende Tabelle erklärt kurz die Elemente in der Grafik oben. Die nicht erwähnten Elemente sollten anhand ihres Namens selbsterklärend sein.

Tabelle 2: Erklärung CaptivePortal-Elemente

Element	Erklärung
Zertifikat	Mit einem Zertifikat kann eine Webseite HTTPS-fähig gemacht werden.
SSL/TLS Profile	Das SSL/TLS-Profil spezifiziert, welche TLS-Version vom Browser mindestens unterstützt werden muss, damit eine Verbindung aufgebaut wird.
Authentication Method	Die Authentication Method bestimmt, wie der Nutzer sich authentifizieren muss, zum Beispiel über ein Webformular.
Authentication Profile	Das Authentication Profile beschreibt, wo die zu prüfenden Nutzerdaten abzufragen sind (lokale DB, Active Directory etc.).
Authentication Enforcement	Authentication Enforcement verbindet Authentication Methode und Ort der Nutzerdaten (Authentication Profile).
Authentication Policy Rule	Die Authentication Policy Rule beschreibt, WER sich WANN auf welche ART (Authentication Enforcement) authentifizieren muss.

Captive Portal Settings	In den Captive Portal Settings werden alle Einstellungen zum Captive Portal, wie Authentifizierungs-Timeout-Zeit, konfiguriert. Zudem kommen hier SSL/TLS Profile und Authentication Profile zusammen.
Interface Management Profile	Im Interface Management Profile wird konfiguriert, welche Services auf einem Firewall-Interface aufgeschaltet sind (zum Beispiel Ping-Antworten).

6.2.1 DNS-Eintrag erstellen

Das Captive Portal braucht, wie gewöhnliche Webseiten auch, einen DNS-Namen, über welchen das Captive Portal angesprochen werden kann. In der bereitgestellten Konfiguration ist bereits ein DNS Forwarding konfiguriert. Auf dieses werden wir nun aufbauen.

1. Navigieren Sie in den **Network**-Tab und wählen Sie das **DNS Proxy**-Menü. Editieren Sie den bestehenden DNS-Proxy namens **DNS Forwarder**.
2. Erstellen Sie im **Static Entries**-Tab einen neuen Eintrag mit folgenden Eigenschaften.

Tabelle 3: Angaben für den DNS-Eintrag für **Captive Portal**.

Spalte	Inhalt
Name:	captiveportal
FQDN:	captiveportal.mydomain.ch
Address:	192.168.10.1

Dies sollte danach in etwa folgendermassen aussehen.

The screenshot shows the 'DNS Proxy' configuration window. The 'Static Entries' tab is selected, displaying a table with the following data:

NAME	FQDN	ADDRESS
captiveportal	captiveportal.mydomain.ch	192.168.10.1

At the top, the 'DNS Forwarder' proxy is configured with 'Enable' checked, 'Name' as 'DNS Forwarder', 'Inheritance Source' as 'ethernet1/3', and 'Primary'/'Secondary' as 'inherited'. The 'INTERFACE' list on the right shows 'ethernet1/1' and 'ethernet1/2'.

Abbildung 24: DNS-Eintrag CaptivePortal.

6.2.2 Zertifikat für Captive Portal ausstellen

Damit eine Webseite über HTTPS angesprochen werden kann, benötigen Sie ein gültiges Zertifikat. Im Kapitel 4 haben Sie bereits eine sogenannte Certification Authority (CA) auf Ihrer Firewall konfiguriert. Diese kann uns nun ein Zertifikat für unser Captive Portal ausstellen.

1. Navigieren Sie in den **Device**-Tab und wählen Sie das **Certificates**-Menü. Generieren Sie ein neues Zertifikat mit folgenden Angaben.

TYPE	VALUE
☒ Host Name = "DNS" from Subject Alternative Name (SAN) field	captiveportal.mydomain.ch

Abbildung 25: Certificate für Captive Portal.

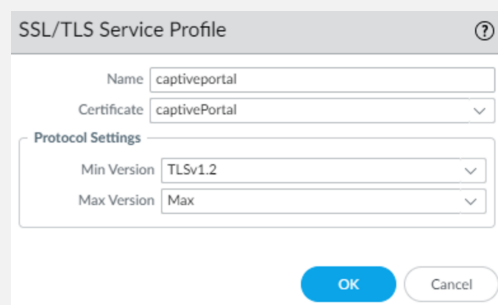


Achten Sie darauf, dass Sie keine Tippfehler machen. **Common Name** und **Certificate Attributes** müssen genau stimmen. Ansonsten ist das Zertifikat nicht gültig!

6.2.3 SSL/TLS Profile erstellen

Als nächstes erstellen wir ein **SSL/TLS Service-Profil**.

1. Wählen Sie dazu das **SSL/TLS Service Profile**-Menü (auch im **Device**-Tab).
2. Erstellen Sie ein **Service Profile** und wählen Sie das zuvor generierte Zertifikat aus. TLS kleiner Version 1.2 wurde im Jahre 2020 als veraltet erklärt und von gängigen Browserherstellern nicht mehr unterstützt werden. Darum können wir getrost als Minimum-Version TLSv1.2 wählen.

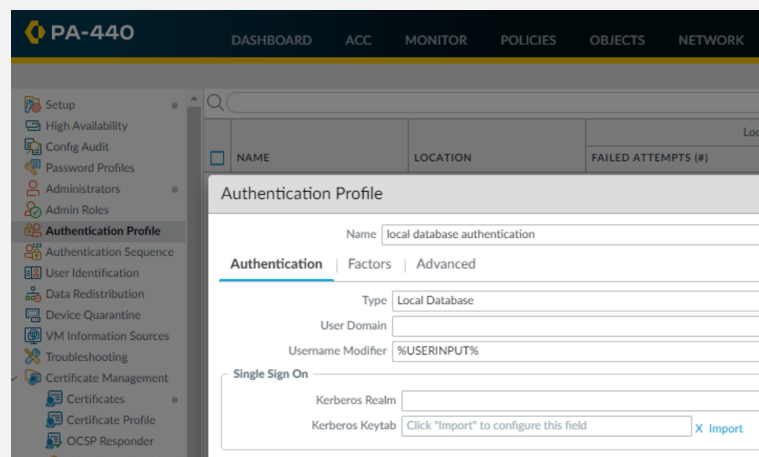


The screenshot shows the 'SSL/TLS Service Profile' configuration window. It has a title bar with a question mark icon. Inside, there are two input fields: 'Name' with the value 'captiveportal' and 'Certificate' with a dropdown menu showing 'captivePortal'. Below these is a 'Protocol Settings' section with two dropdown menus: 'Min Version' set to 'TLSv1.2' and 'Max Version' set to 'Max'. At the bottom right are 'OK' and 'Cancel' buttons.

Abbildung 26: SSL/TLS Service Profile.

6.2.4 Authentication Profile erstellen

1. Wechseln Sie ins **Authentication Profile**-Menü (auch im **Device**-Tab).
2. Erstellen Sie ein neues **Authentication Profile**. Im **Authentication**-Tab muss als Type **Local Database** ausgewählt sein. Darin ist der zuvor erstellte Benutzer gespeichert. Im **Advanced**-Tab muss unter Allow List **all** hinzugefügt werden.



The screenshot shows the 'PA-440' interface with a sidebar on the left containing various configuration options like Setup, High Availability, Config Audit, Password Profiles, Administrators, Admin Roles, Authentication Profile (selected), Authentication Sequence, User Identification, Data Redistribution, Device Quarantine, VM Information Sources, Troubleshooting, Certificate Management, Certificates, Certificate Profile, OCSP Responder, and SSL/TLS Service Profile. The main area displays the 'Authentication Profile' configuration. It has tabs for 'Authentication', 'Factors', and 'Advanced'. The 'Authentication' tab is active, showing 'Name' as 'local database authentication', 'Type' as 'Local Database', 'User Domain' as an empty field, and 'Username Modifier' as '%USERINPUT%'. There is a 'Single Sign On' section with 'Kerberos Realm' and 'Kerberos Keytab' fields. The 'Kerberos Keytab' field has a button that says 'Click "Import" to configure this field' and an 'Import' button.

Abbildung 27: Authentication Profile erstellen.

6.2.5 Captive Portal konfigurieren

Wir haben alle vorbereitenden Einstellungen für die **Captive Portal**-Konfiguration vorgenommen. Jetzt können wir das Portal selbst konfigurieren.

1. Im **User Identification**-Menü (auch im **Device**-Tab) müssen die **Authentication Portal**-Einstellungen analog zur Abbildung 28 unten editiert werden. Der Editier-Dialog kann mit dem Zahnradsymbol im oberen rechten Eck geöffnet werden.

Setzen Sie das zuvor erstellte **SSL/TLS Service Profile** und das **Authentication Profile**. Fügen Sie im **Redirect Host**-Feld den FQDN des zuvor erstellten DNS-Eintrags ein.

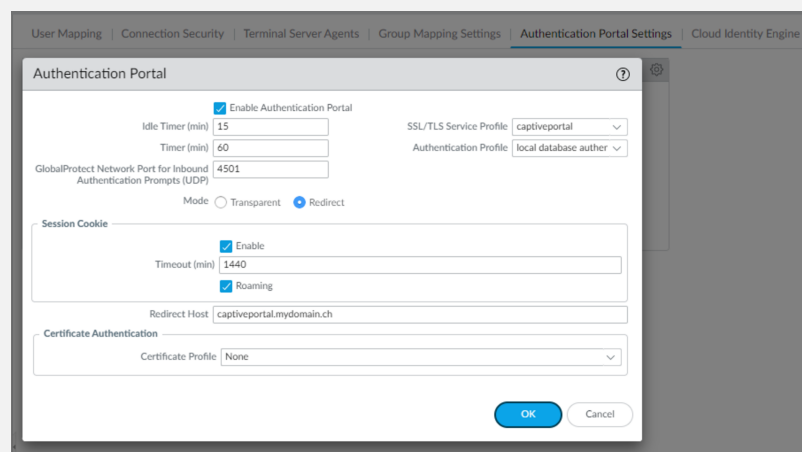


Abbildung 28: FQDN für Captive Portal eintragen.

2. Was ist ein FQDN?

Fully Qualified Domain Name (FQDN), voller Name mit dem ein Netzwerkgerät eindeutig identifiziert werden kann. Es bezeichnet innerhalb des Domain Name Systems (DNS) den vollständigen Domain-Namen einer Internetpräsenz oder eines Hosts.

6.2.6 Authentication Enforcement

Als nächstes muss die Authentifizierungs-Art mit dem **Authentication Profile** verknüpft werden. Dies geschieht mittels **Authentication Enforcement**.

1. Navigieren Sie in den **Objects**-Tab und öffnen Sie das **Authentication**-Menü. Fügen Sie per **Add** ein **Authentication Enforcement** hinzu.
2. Wählen Sie die bereits in der Default-Konfiguration vorhandene **web-form** Authentication Method aus. Als **Authentication Profile** wird das zuvor erstellte Profil verwendet.

Verwenden Sie eine aussagekräftige Nachricht. Diese wird dem Benutzer beim Einloggen auf der Webseite angezeigt.

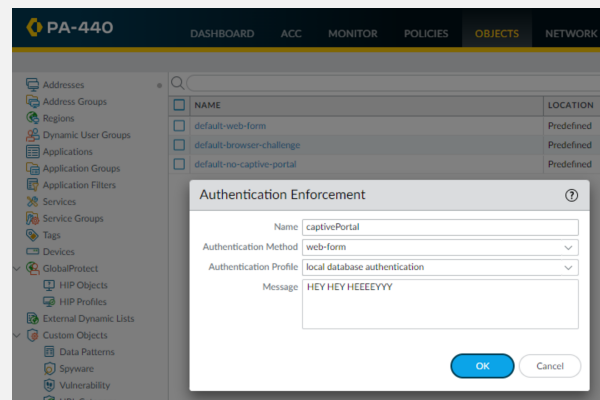


Abbildung 29: Authentication Enforcement konfigurieren.

6.2.7 Authentication Policy Rule

Die Authentication Policy Rule bestimmt, wer sich für die definierten Services authentifizieren muss.

1. Navigieren Sie zum **Policies**-Tab und öffnen Sie das **Authentication**-Menü.

- Erstellen Sie eine neue **Authentication Policy Rule** mit folgenden Attributen.

Tabelle 4: Attribute der **Authentication Policy Rule**.

Feld	Wert
Source:	inside
User:	any
Destination:	any (Zone/Address)
Service / URL Category:	service-https und service-http
Action:	Zuvor erstellte Authentication Enforcement captivePortal

Hier könnte man auch basierend auf verschiedenen Nutzern oder Gruppen verschiedene Anforderungen zur Authentifizierung hinterlegen. In unserem Beispiel muss sich jeder authentifizieren der einen Service via **HTTP** oder **HTTPS** nutzen möchte. Nutzer-basierte Regeln folgen später in Kapitel 7.2.

6.2.8 User Identification aktivieren

Damit **User Identification** via Login betrieben werden kann, muss dies auf der Firewall-Zone aktiviert werden.

- Navigieren Sie in den **Network**-Tab und öffnen Sie das **Zones**-Menü. Öffnen Sie die Konfiguration der **Inside**-Zone und aktivieren Sie die Option **Enable User Identification**.

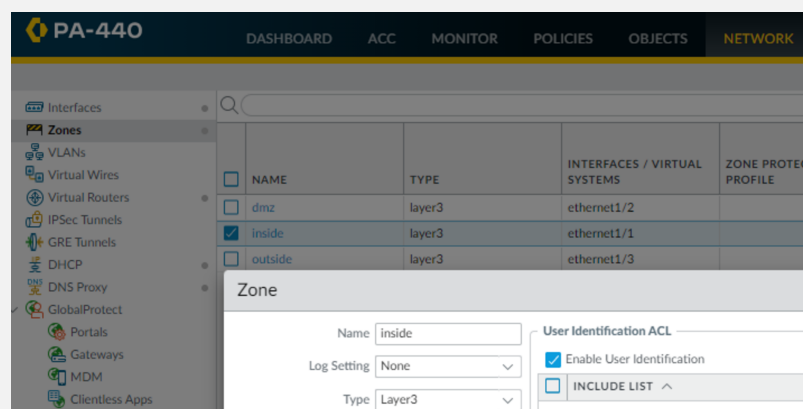


Abbildung 30: User Identification aktivieren.

6.2.9 Captive Portal auf Inside-Interface aufschalten

Das Captive Portal kann bei einer Palo Alto nicht einfach so über das **Inside**-Interface erreicht werden. Dieser Zugriff muss zuerst freigeschaltet werden.

1. Navigieren Sie dazu in den **Network**-Tab und wählen Sie das **Interface Mgmt**-Menü innerhalb **Network Profiles**.
2. Erstellen Sie ein neues Interface Management Profile mit dem Namen **allow_captivePortal**.
3. Erlauben Sie bei dem neuen Profil die Network Services **Ping** und **Response Pages** (Captive Portal). Wählen Sie den IP-Adressrange des **Inside**-Netzwerks als **Permitted IP Addresses**.

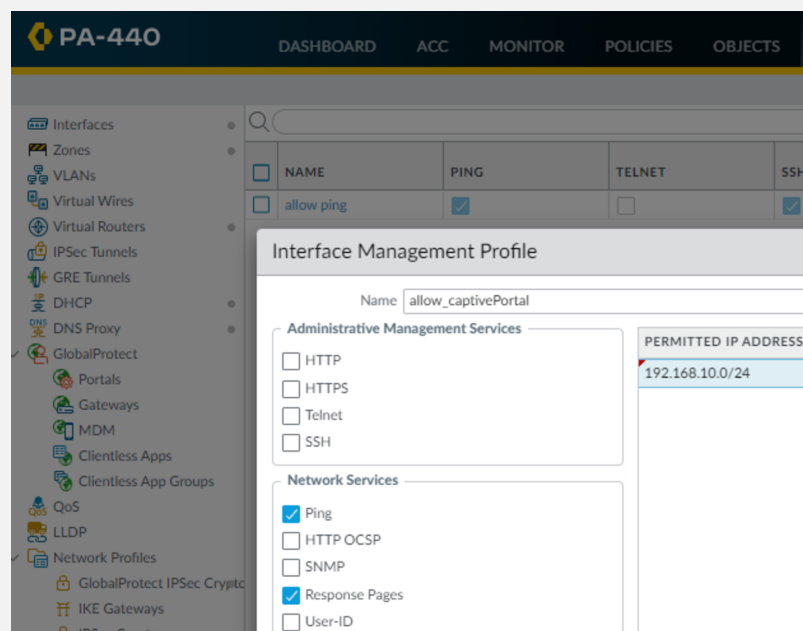


Abbildung 31: Captive Portal im Interface Management Profile erlauben.

4. Jetzt muss das erstellte Management-Interface-Profil auf das entsprechende Interface angewendet werden. Öffnen Sie dazu das **Interfaces**-Menü. Wählen Sie das **Inside-Interface** (**ethernet1/1**) und wenden Sie im **Advanced**-Tab das neu erstellte Management-Profil an.

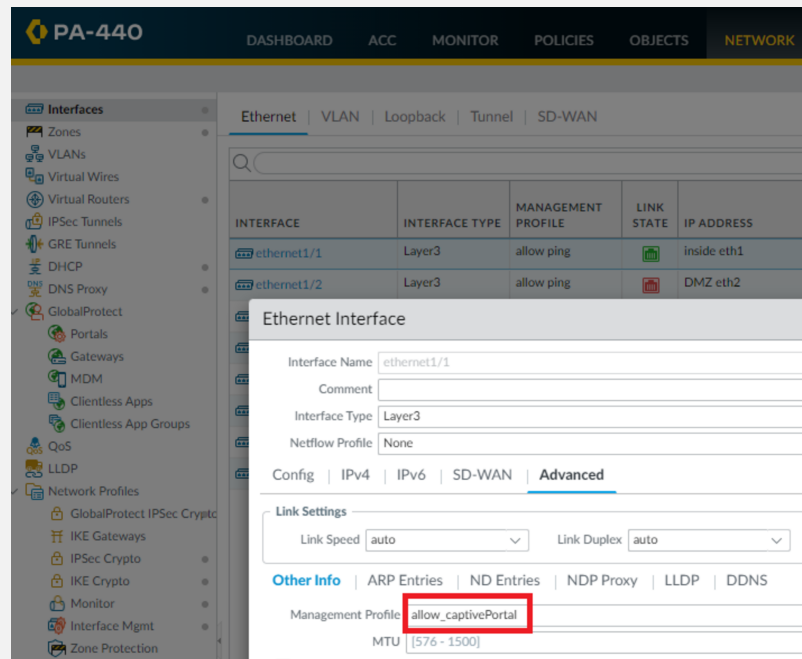


Abbildung 32: Interface Management Profile anwenden.

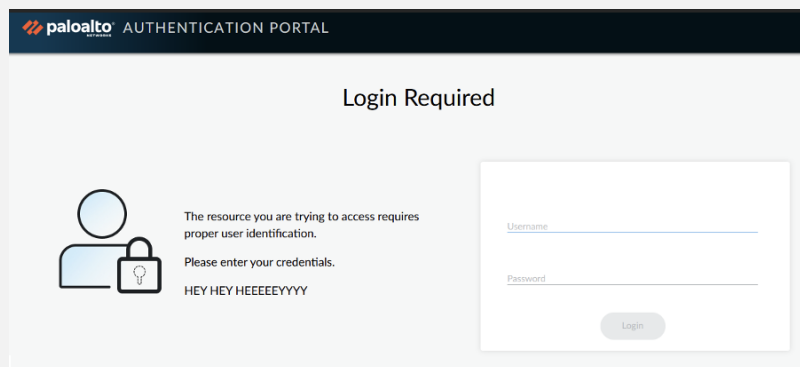
5. Wie mit jeder Konfigurationsänderung muss auch hier committet werden, damit die Änderungen aktiv werden.
6. Warum ist die Benutzerverwaltung auf der PA-440 nicht die beste Lösung? Begründen Sie!
Hinweis: Betrachten Sie ein Szenario mit einem KMU mit 200 Mitarbeiter.

Es ist nicht sinnvoll die Benutzerverwaltung dezentral auf der Firewall vorzunehmen. Besser ist das Einbinden der **Active Directory** des Unternehmens oder das Einbinden eines externen Verzeichnisseservers (LDAP).

6.2.10 Captive Portal testen

Testen Sie nun Ihre **Captive Portal**-Konfiguration.

1. Öffnen Sie dazu eine beliebige Webseite. Sie sollten nun auf das **Captive Portal** umgeleitet werden. Eventuell ist auch ein zweiter Refresh der Webseite notwendig.
2. Authentifizieren Sie sich mit dem zuvor erstellten Nutzer.



The screenshot shows the Palo Alto Authentication Portal interface. At the top, there is a dark blue header with the Palo Alto logo and the text "AUTHENTICATION PORTAL". Below the header, the main content area has a light blue background. In the center, the text "Login Required" is displayed. To the left of the login form, there is an icon of a person with a lock and a lightbulb, followed by the text: "The resource you are trying to access requires proper user identification. Please enter your credentials. HEY HEY HEEEEYYYY". To the right of this text is a white login form with two input fields labeled "Username" and "Password", and a "Login" button at the bottom.

Abbildung 33: Anmeldemaske mit der zuvor festgelegten Willkommensmeldung.

7 Layer 7-Web-Filtering

7.1 URL-Blocking

In einem ersten Schritt wollen wir herkömmliches **URL-Blocking** anhand einer Referenzanforderung implementieren. Dabei wird jeder Aufruf an eine verbotene URL blockiert und eine Webseite mit entsprechender Meldung angezeigt. Folgende Anforderung werden Sie in diesem Kapitel umsetzen.

In Rotkreuz ist das Wetter grundsätzlich immer mies. Es macht keinen Sinn, Wetter-Webseiten zu besuchen, denn die Prognose kann nur schlecht sein. Um Bandbreite beim Internet-Uplink Ihres Unternehmens zu sparen, sollen darum Wetter-Webseiten blockiert werden.

1. Welche Website-Kategorien könnten mit welcher Begründung im Unternehmensumfeld auch blockiert werden?

Nennen Sie ein paar vernünftige Beispiele mit Begründung, warum es Sinn machen kann diese zu blockieren!

Social Media, Malware, Foren, Twitch/YouTube, ... Alles was nicht zum Arbeiten benötigt wird.

2. Navigieren Sie in den **Objects**-Tab und wechseln Sie in das **URL Category**-Menü unter **Custom Objects**.
3. Erstellen Sie eine **Custom URL Category** namens **block weather**. Fügen Sie ein paar gängige Wetter-Webseiten hinzu. Mit dem Asterisk-Symbol * können Wildcards definiert werden.

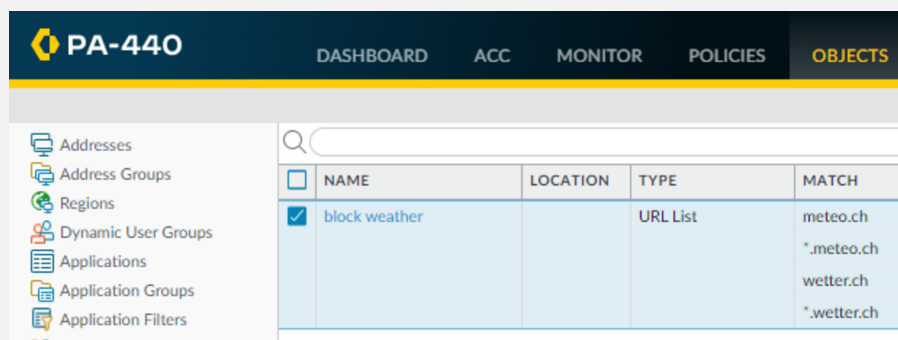


Abbildung 34: URL Category erstellen.

4. Wechseln Sie in den **Policies**-Tab und öffnen Sie das **Security**-Menü.
5. Erstellen Sie eine neue **Security Rule** **oberhalb** der **inside-outside-allow**-Regel. Konfigurieren Sie die Parameter wie folgt.

Tabelle 5: Konfiguration der **Security Rule**.

Feld	Parameter
Source	inside
User	any
Destination	outside
Application	any
Service	any
URL Category	block weather
Action	Deny

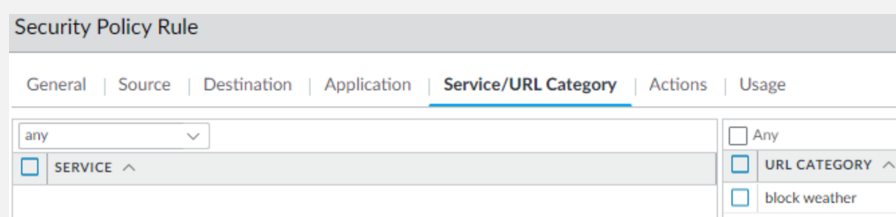


Abbildung 35: URL Category zu Security Policy Rule hinzufügen.

6. Wie immer müssen Änderungen mittels **Commit** aktiviert werden.
7. Geben Sie eine Vermutung ab, was Ihnen angezeigt wird, wenn Sie nachher eine der blockierten Seiten öffnen!

Nichts, die Verbindung wird blockiert. → Standard-Browser «keine Verbindung»-Screen.

Richtige Antwort: Web Page mit **Blocked Content** von der Palo Alto-Firewall.

8. Sind die untenstehenden Domains von der URL Category **block weather** betroffen?

Beantworten Sie folgende Statements mit **Ja** oder **Nein**!

meteo.ch

mobile.meteo.ch

meteo.com

www.wetter.ch

weter.ch

ja, ja, nein, ja, nein

9. Verifizieren Sie Ihre Antworten oben, nachdem der Commit durchgeführt wurde.

7.2 URL-Blocking auf Nutzer-Basis

Wie jeden Dienstagnachmittag kommen Sie gut genährt vom Mittagessen zurück und schauen zuerst mal, was für neue E-Mails Sie erhalten haben. Ein weitergeleitetes Mail mit dem Betreff *so nicht* sticht Ihnen sofort ins Auge. Sie lesen den E-Mail-Verlauf und finden heraus, dass ein Mitglied des Verwaltungsrates, seines Zeichens Meteorologe, im Haus war und das Wetter via Internet prüfen wollte. Bekanntlich haben Sie die Wetter-Webseiten in Kapitel 7.1 blockiert. Der IT-Leiter, an welchen das Mail adressiert war, hat Ihnen das Mail kommentarlos weitergeleitet. Sie wissen was zu tun ist!

Nach kurzer Absprache mit Ihren Kollegen entscheiden Sie sich, die Wetter-Webseiten nur noch für die Normalbürger zu sperren.

1. Erstellen Sie nochmals einen neuen Benutzer. Wenn Sie unsicher sind, wie es funktioniert, folgen Sie den Anweisungen in Kapitel 6.1.

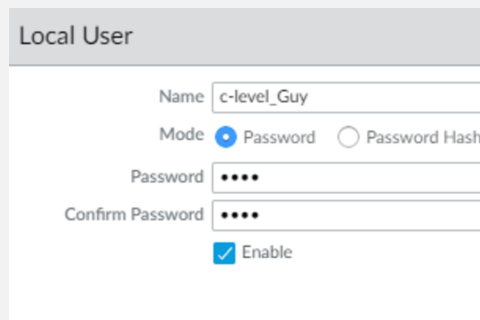


Abbildung 36: Zusätzlichen User erstellen.

2. Erstellen Sie zudem eine neue Gruppe und fügen Sie den in Kapitel 7.1 erstellten Benutzer der Gruppe hinzu. Sie finden das entsprechende Menü im *Device*-Tab.

3. Wechseln Sie nun wieder zurück in den **Policies**-Tab und öffnen Sie das **Security**-Menü. Editieren Sie die bestehende Wetter-Webseiten-Regel und fügen Sie im Tab **Source** die gerade eben erstellte Gruppe hinzu.

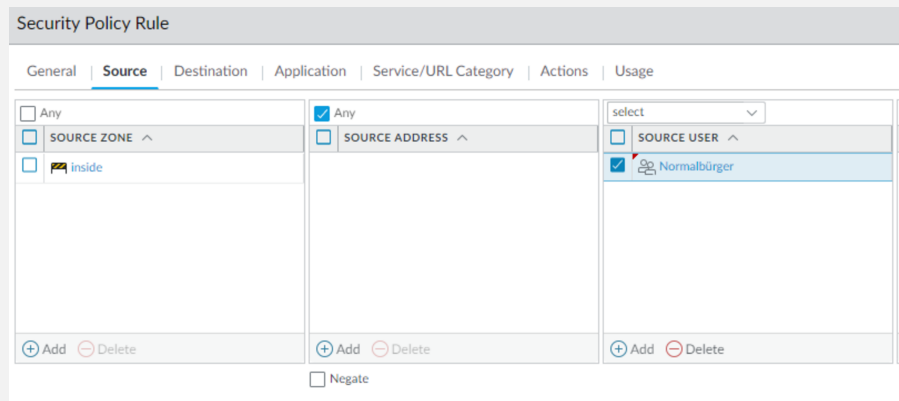


Abbildung 37: User-Gruppe zu Security Policy Rule hinzufügen.

4. Wie gewohnt müssen die Änderungen mittels **Commit** aktiviert werden.
5. Wer hat nun Zugriff und wer nicht? Erklären Sie kurz in eigenen Worten!

Alle User der Gruppe **Normalbürger** haben *keinen* Zugriff (hier hat nur der **c-level_Guy**), alle anderen schon. Da es eine Deny-Regel ist, haben Nutzer, die nicht in der erstellten Gruppe sind, Zugriff.



Für das Weitere ist gut zu wissen: Das Default-Timeout für die **Captive Portal**-Authentifizierung liegt bei 60 Minuten Inaktivität.

6. Nun möchten wir den Verhaltensunterschied zwischen den zwei Benutzern testen. Sie haben nun zwei Möglichkeiten: entweder Sie warten eine Stunde bis zum Inaktivitäts-Timeout oder Sie setzen die **Captive Portal**-Sessions manuell zurück. Leider wird diese Funktionalität über das Web-GUI nicht angeboten.
7. Öffnen Sie vom Management-PC aus mit **PuTTY** eine SSH-Verbindung zur **Management IP** der Firewall (192 . 168 . 1 . 1). Loggen Sie sich mit den Login-Daten ein - genau gleich wie über das Webinterface **admin/Hslu1234**.

8. Setzen Sie den folgenden Befehl ab, um die **Captive Portal**-Sessions zurückzusetzen. Ersetzen Sie dabei `192.168.10.<?>` durch die IP-Adresse des Labor-PCs in der **inside**-Zone. Die IP-Adresse wird per DHCP vergeben und kann variieren. In der Regel lautet sie `192.168.10.100`.

```
debug user-id reset captive-portal ip-address 192.168.10.<?>
```

9. Rufen Sie die Webseite <https://www.meteo.ch> erneut auf. Sie sollten sich nun neu authentifizieren müssen.
10. Authentifizieren Sie sich mit dem ersten User. Sie stellen fest, die Webseite ist immer noch blockiert.
11. Nun möchten wir das Verhalten mit dem frisch angelegten Useraccount testen. Setzen Sie in der **PuTTY**-Session den gleichen Befehl nochmals ab.

```
debug user-id reset captive-portal ip-address 192.168.10.<?>
```

12. Nun sollten Sie sich nach einem Refresh der Webseite wieder am **Captive Portal** authentifizieren müssen. Falls Sie eine **CONNECTION RESET**-Meldung erhalten, einfach nochmals neu laden.
13. Loggen Sie sich nun mit dem in dieser Teilübung erstellten Benutzer ein. Sie stellen fest, dass Sie mit diesem Benutzer ohne weiteres auf der verbotenen Wetter-Webseite <https://www.meteo.ch> surfen können.

7.3 Application Filtering

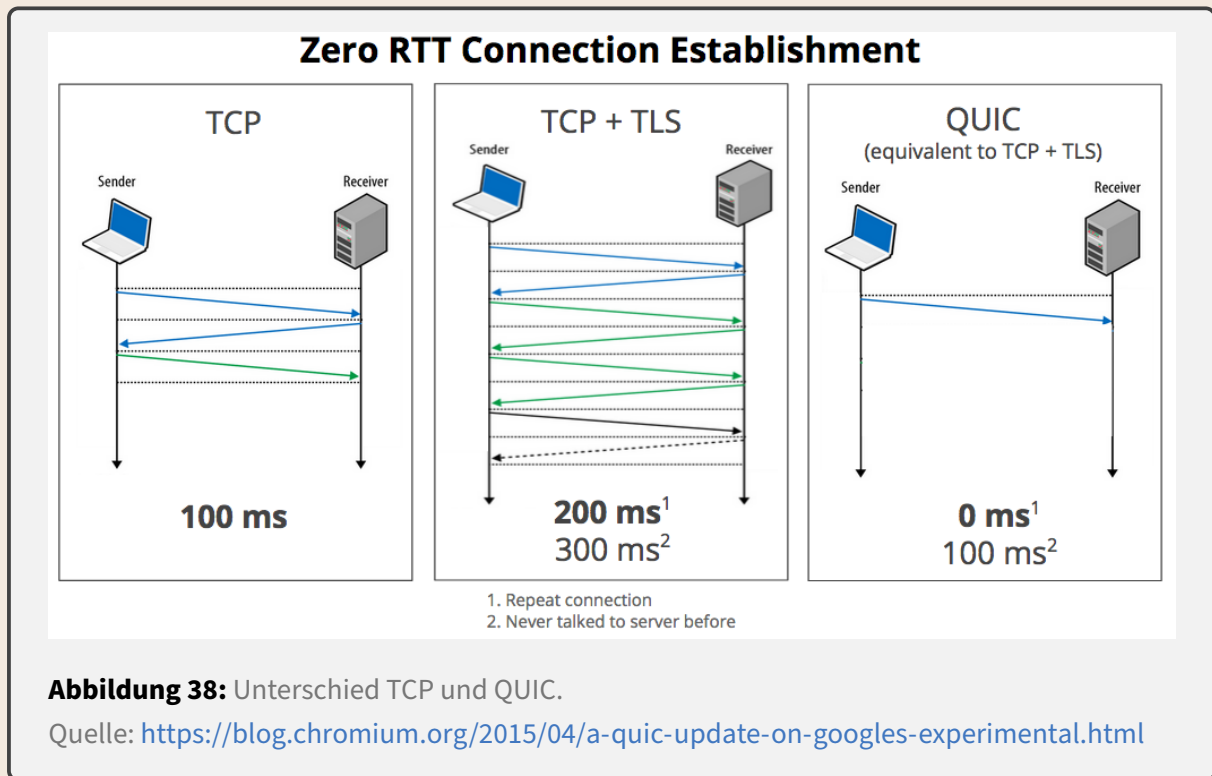
In Ihrer IT-Abteilung besprechen Sie im Team, was gegen die hohe Auslastung des Internetanschlusses gemacht werden kann. Sie wissen, dass ein grosser Teil der verwendeten Bandbreite YouTube-Streaming ausmacht. Ihr Team beschliesst, dass YouTube-Videostreaming für die tägliche Arbeit betrieblich nicht relevant ist und Sie blockieren mittels URL-Filtering von youtube.com.

Es dauert nicht lange, bis Ihr Vorgesetzter ein Mail mit dem Betreff so nicht erhält. Die Marketingverantwortlichen müssen Fragen von Usern, die via Kommentarfunktion gestellt werden, beantworten können. Nach einem Schlagabtausch in der Cafeteria einigt man sich darauf, dass das Streamen von Videos blockiert werden soll, aber die restlichen Funktionalitäten der Webseite verfügbar sein müssen. Diese Anforderung kann mit URL-Filtering nicht abgedeckt werden. Es muss ein Feature her, welches anhand des Inhalts von Paketen bestimmen kann, um welche Applikationsfunktionalität es sich handelt. Ihr Firewall-Kollege schlägt vor, das NextGen Feature Application Filtering zu verwenden. Dieses Feature wird in diesem Kapitel konfiguriert.

Der Mozilla Firefox-Browser hat standardmässig das QUIC-Transport-Protokoll aktiviert, welches auf UDP basiert. QUIC steht für Quick UDP Internet Connections. Dieses von Google im Jahre 2012 vorgestellte und seit Mai 2021 durch die IETF standardisierte Protokoll soll den Internetdatenverkehr beschleunigen. Dabei ändern sich im Vergleich mit TCP vor allem folgende Punkte:

- Es wird auf den Verbindungsaufbau-Overhead von TCP verzichtet.
- Nutzdaten können bereits im ersten Paket mitgegeben werden.
- TLS 1.3 (Verschlüsselung) ist im Protokoll standardmässig integriert.

Google selbst hat im Jahre 2015 folgende Grafik veröffentlicht. Die genauen Zeiten in Millisekunden können ignoriert werden, da die Nachvollziehbarkeit im Rahmen dieser Übung nicht gegeben ist. Trotzdem ist auf einen Blick ersichtlich, dass viel weniger Pakete für den Verbindungsaufbau versendet werden. Verbindungsdaten werden in QUIC verbindungslos (UDP) an den Receiver gesendet und müssen von diesem darum nicht bestätigt werden. Im Initialpaket sind auch Verschlüsselungsparameter für TLS 1.3 enthalten. Dieses Prinzip wird Zero Round Trip Time (0-RTT) genannt.



1. **QUIC** hat aber nicht nur Vorteile. Bezüglich der Sicherheit birgt QUIC einige Herausforderungen. Was könnten die Challenges sein?

Hinweis: Sehen Sie sich das QUIC-Protokoll im OSI-Modell an und lesen Sie [Anhang 11 – How QUIC Impacts Network Security](#).

QUIC birgt einige Sicherheits Herausforderungen, z.B. die Schwierigkeit, den verschlüsselten Verkehr zu überwachen und zu filtern sowie die Möglichkeit von DoS-Angriffen.

Beispielsweise besteht eine Herausforderung darin, dass QUIC von Sicherheitsnetzwerkgeräten wie Firewalls noch nicht unterstützt wird und daher für viele Unternehmen unbeabsichtigt eine Sicherheitslücke geschaffen hat.

Die meisten Firewalls verfügen über umfangreiche Funktionen für den Umgang mit HTTP- und HTTPS-Verkehr. In den meisten Architekturen wird der erkannte HTTP-Verkehr an ein Web-Scanning-Modul weitergeleitet, das Webfilterung, Deep Packet Inspection usw. durchführt. HTTP-Verkehr wird gesondert behandelt, da die Firewalls den Verkehr von Layer 4 bis Layer 7 interpretieren können. Die Behandlung umfasst Malware-Scans und in den meisten Fällen eine verbessertes Reporting.

QUIC verwendet die traditionellen HTTP-Ports 80 und 443, aber hier enden die Ähnlichkeiten. Die unterstützenden Browser und Server unterstützen dieses neue Protokoll und können es als Webverkehr verarbeiten, aber das dazwischenliegende Netzwerkgerät kann das Anwendungsprotokoll nicht ermitteln und geht dazu über, es wie jeden generischen Layer-4-UDP-Verkehr zu behandeln.

2. Wechseln Sie in den **Policy**-Tab und öffnen Sie das **Security**-Menü. Erstellen Sie eine neue Security Policy Rule. Blockieren Sie ausgehenden QUIC-Traffic. Sie finden QUIC unter Application. Vergessen Sie nicht Service auf **any** umzustellen!

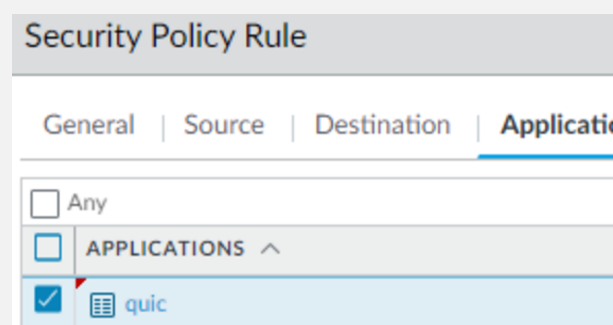


Abbildung 39: QUIC-Protokoll zu **Security Policy** hinzufügen.

3. Wie immer müssen Änderungen mittels **Commit** aktiviert werden.

4. Testen Sie, ob die YouTube-Videos blockiert werden. Falls nicht, woran könnte es liegen?
Hinweis: Überprüfen Sie den Netzwerkverkehr mit Wireshark.

Das Video wird nicht geblockt, siehe auch [Anhang 11](#). Es wird von YouTube zum Transportprotokoll **TCP** gewechselt und kein QUIC mehr verwendet. Deshalb funktioniert das Video noch.

5. Um die YouTube-Videos blockieren zu können, muss das Application-Filtering auf das **QUIC**-Protokoll und **youtube-streaming** angewandt werden. Letzteres blockiert auch **TCP**-YouTube-Verkehr. Erstellen Sie dementsprechend eine zweite **Security Policy** mit folgenden Angaben:

Tabelle 6: **Security Policy** für YouTube mit QUIC.

Feld	Option
Source	any
User	any
Destination	outside
Application	youtube-streaming
Service / URL Category	any
Action	Deny

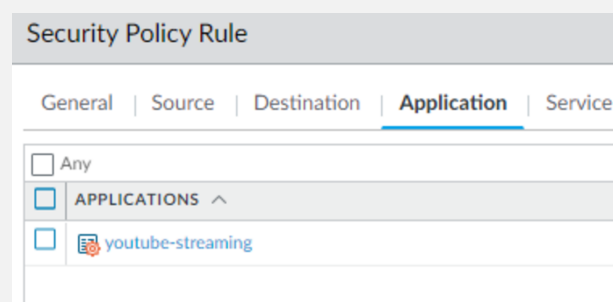


Abbildung 40: Application **youtube-streaming** hinzufügen.

6. Wie immer müssen Änderungen mittels **Commit** aktiviert werden.

7. Testen Sie, ob die YouTube-Videos blockiert werden. Dokumentieren Sie Ihre Erkenntnisse.

Die Videos werden erfolgreich blockiert.

8 Social Media Tracking

Das Wallstreet Journal hat im März 2018 ein knapp vier-minütiges Video veröffentlicht, dass auf die Tracking-Methoden von Facebook hinweist. Dazu gehören neben Location oder Korrelation mit 3rd Party-Daten auch ganz simpel der **Facebook Like**-Button, der auf vielen Webseiten noch zu finden ist.

Das Video finden Sie bei Interesse hier: <https://www.wsj.com/articles/facebook-really-is-spying-on-you-just-not-through-your-phones-mic-1520448644>.

Eine etwas neuere Technologie ist **Facebook Pixel**. Hier erscheint auf der Webseite nicht ein für jeden wahrnehmbaren Like-Button, sondern ein verstecktes Stück Code. Aber was sind die Benefits dieses Pixels?

1. Grundsätzlich kann das Pixel, wie auch der Like-Button aufzeichnen, auf welchen Internet-Seiten sich der im Browser eingeloggte Facebook Account bewegt. Dabei muss die Facebook Webseite an sich auch nicht offen oder ähnliches sein. Es reicht, wenn sich auf der angesurften Webseite ein **Facebook Pixel** verbirgt.
2. Das Pixel bietet **Ende-zu-Ende**-Tracking. Dabei wird ausgewertet, ob jemand, der über eine Facebook Anzeige auf meine Webseite gelangt ist, meinen Service (Verkauf Dienstleistungen, Waren etc.) schlussendlich auch kauft oder sich nur umschaute. Dazu wird ein Stück Code auf der Webseite eingebunden, welches das Tracking übernimmt. Der Service Anbieter kann sich die Statistiken in einer Weboberfläche anzeigen.
3. Retargeting Ads: Anzeigen, welche Leuten gezeigt werden, welche schon einmal auf der Webseite des Unternehmens oder sonst in Kontakt mit dem Unternehmen standen. Ein Beispiel: Ich füge einen Artikel meinem Warenkorb hinzu, kaufe es aber nicht. Nun werden mir auf Facebook etc. Werbung zu diesem Produkt angezeigt, in der Hoffnung, dass ich es doch noch kaufen werde. Gemäss Cat Howell werden sehr viele Produkte zwar in den Warenkorb gelegt, aber nicht gekauft.

Diese und weitere Vorteile von **Facebook Pixel** werden von Cat Howell, einer renommierten Fachfrau im Bereich Facebook Advertising, in diesem Video beschrieben: <https://www.youtube.com/watch?v=z5BeNCBpRNs>.

(Es wird empfohlen das Video mit 1.25-facher Geschwindigkeit zu schauen).

Am 11. April 2018 sagte Mark Zuckerberg vor dem US-Kongress zum **Cambridge Analytica**-Skandal aus. Die Demokratin Debbie Dingell fragte ihn, wie viele **Facebook Pixel** in den Weiten des Internets existieren. Darauf konnte Zuckerberg keine Antwort geben. Wir dürfen ruhig vermuten, dass es sich um eine ziemlich grosse Zahl handeln dürfte.

Hier finden Sie bei Interesse ein Transkript der zweitägigen Befragung: <https://www.theguardian.com/technology/live/2018/apr/11/mark-zuckerberg-testimony-live-updates-house-congress-cambridge-analytica>.

Sie sollten nun genug Gründe haben, das ganze Facebook Tracking blockieren zu wollen. Dank der Layer 7-Fähigkeit unserer Firewall können wir gezielt Facebook Tracking unterbinden ohne Facebook als gesamtes zu blockieren.

1. Navigieren Sie wieder in den Policies-Tab und öffnen Sie das Security-Menü.
2. Erstellen Sie eine neue Security Policy mit passender Source- und Destination-Konfiguration. Wählen Sie als Application facebook-social-plugin. Beachten Sie, dass in der Service-Konfiguration any ausgewählt ist.

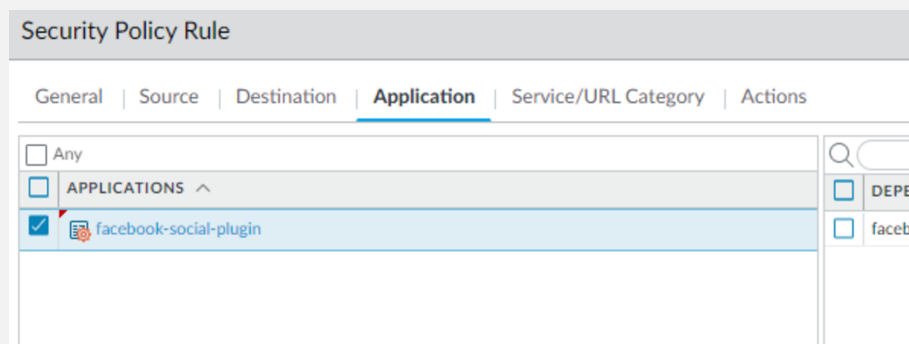


Abbildung 41: Facebook Social Plugin zu Security Policy Rule hinzufügen.

3. Wie gewohnt müssen auch hier die Änderungen mittels Commit aktiviert werden.

Update:

Dank DSGVO wurde das Tracking mittels Like-Button und dergleichen ein wenig eingeschränkt. Neu kann der Like Button nur verwendet werden, wenn man bei seinem Facebook-Konto angemeldet ist und Cookies für Apps und Webseiten genehmigt hat. Facebook hat folgendes Statement dazu geschrieben:

Bei sozialen Plugins kann es demnächst zu gewissen Beeinträchtigungen kommen. Grund dafür ist eine aktualisierte Aufforderung zur Einwilligung in Cookies, die Nutzern von Facebook-Produkten in der Region Europa angezeigt wird. Für Benutzer aus der Region Europa werden die sozialen Plugins **Gefällt mir** und **Kommentieren** nur noch dann unterstützt, wenn die Benutzer 1) bei ihrem Facebook-Konto angemeldet sind und 2) ihre Zustimmung zu Cookies für Apps und Websites erteilt haben. Wenn diese Bedingungen beide erfüllt sind, können Benutzer-Plugins wie die **Gefällt mir**- oder **Kommentieren**-Buttons sehen und nutzen. Ist eine dieser Bedingungen nicht erfüllt, können Benutzer diese Plugins nicht sehen.

Quelle: https://developers.facebook.com/docs/plugins/like-button/?locale=de_DE (Stand 05.09.2022)

9 Aufräumen

Wenn Sie mit der Übung fertig sind, bitten wir vom Laborteam Sie, das Gerät zurückzusetzen. Sie erweisen auch der nächsten Person, die die Firewall benutzt, einen Gefallen.

Eingebundene Zertifikate

1. **Löschen Sie unbedingt Ihr generiertes Zertifikat** aus dem Zertifikatsspeicher von Windows. Bitte stellen Sie sicher, dass das Zertifikat aus dem Speicher **Current User** und **Local Computer** entfernt ist.

1. Starten Sie mit <WINDOWS-Taste>-r das **Ausführen-Menü**.

Starten Sie den Zertifikatsmanager für **Current User** mit dem Befehl `certmgr.msc`. Löschen Sie das Zertifikat `fw01.mydomain.ch` aus dem Store **Trusted Root Certification Authorities**.

2. Starten Sie mit <WINDOWS-Taste>-r das **Ausführen-Menü**.

Starten Sie den Zertifikatsmanager für **Local Computer** mit dem Befehl `certlm.msc`. Löschen Sie, falls vorhanden, das Zertifikat `fw01.mydomain.ch` aus dem Store **Trusted Root Certification Authorities**.

Firewall-Einstellungen

2. Wechseln Sie in den **Device**-Tab der Palo Alto-Firewall-Konfiguration und wählen Sie das **Setup**-Menü. Wechseln Sie im **Setup**-Menü in den **Operations**-Tab.
3. Wählen Sie **Load Named Configuration Snapshot** und wählen Sie die `default_config.xml` aus.

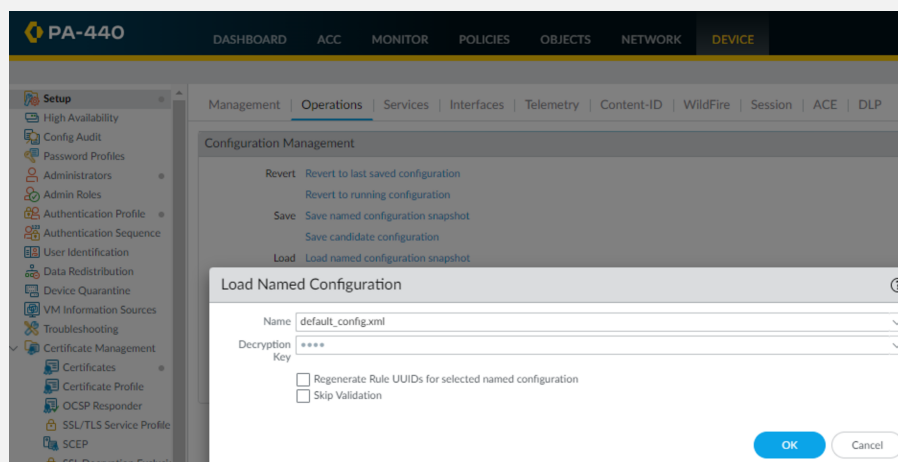


Abbildung 42: Default Config laden.

4. Schreiben Sie die Konfiguration mittels Commit auf das Gerät.
5. Führen Sie zum Abschluss auf den beiden Labor-PCs das `ResetNetworkAdapters`-Script auf dem Desktop aus, damit die Netzwerk-Adapter zurückgesetzt werden (Ausgangslage).

10 Anhang A: Konfiguration vom Ende des Basics-Versuch auf FW laden

Dieses Kapitel beschreibt, wie der Konfigurationsendstand des **Basics**-Versuchs auf die PA-440 geladen werden kann, sollte diese nicht bereits darauf vorhanden sein. Die Konfiguration befindet sich unter folgender URL: https://hsluzern-my.sharepoint.com/:u:/g/personal/florian_wamser_hslu_ch/Ed_eobCecl3NHtgD-d2lyb0gBgtrhpuBtyveilnHCts2v2A?e=yzZvVz

1. Speichern Sie die Konfiguration auf den Desktop oder einen anderen Ort Ihrer Wahl.
2. Öffnen Sie das Management Web-GUI und navigieren Sie in den **Device**-Tab. Öffnen Sie das **Setup**-Menü. Wechseln Sie hier in den **Operations**-Tab.
3. Wählen Sie **Import Named Configuration** und wählen Sie das zuvor abgespeicherte File.

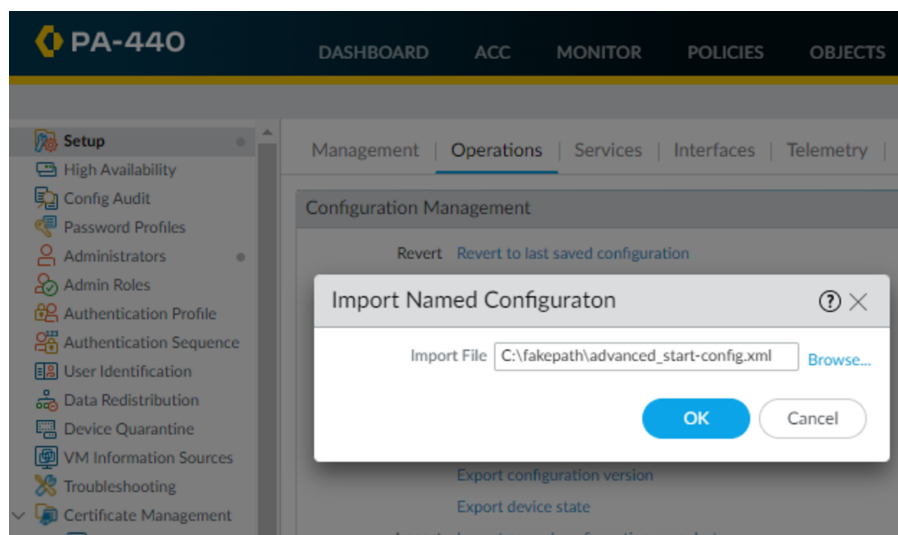


Abbildung 43: Import Named Configuration Dialog.

4. Fahren Sie nun mit der Anleitung normal weiter.

11 Anhang B: How QUIC Impacts Network Security

Abgerufen von <https://www.fastvue.co/fastvue/blog/googles-quic-protocols-security-and-reporting-implications/> am 20. Januar 2024.

How QUIC Impacts Network Security

The issue is not with the protocol or the technology itself. The supposed upside of QUIC is that it makes web communications more efficient and faster. The problem is that it is not supported by security appliances such as firewalls yet, and has therefore inadvertently created a security hole for many organizations.

Most firewalls have extensive functionality when dealing with HTTP and HTTPS traffic. In most architectures, when HTTP traffic is detected, it is passed on to a web protection module that performs web filtering, deep packet inspection etc. HTTP traffic gets special treatment because the firewalls can interpret the traffic from Layer 4 up to layer 7. This special treatment includes malware scanning and in most cases, enhanced reporting.

QUIC uses the traditional HTTP ports of 80 and 443 but that is where the similarities end. The supporting browsers and servers support this new protocol and are able to process it as web traffic, but the network device in between cannot determine the application protocol and switches to treating it like any generic layer 4 UDP traffic.

QUIC traffic is therefore not scrutinized as it should be and it is not forwarded to the firewall's web protection features.

The real world implications of QUIC traffic range from not being able to restrict access to YouTube or enforce Google Safe Search, through to malware or ransomware being downloaded through Gmail or any other QUIC enabled website.

To compound the issue, you will most likely not be aware of any problems since the logging and reporting engines tied to the web protection features are also affected.

To further complicate things, the standards have not been locked down yet and the protocol is frequently revised, which is a reason why firewalls have not yet caught up.

ENDE

Laden Sie das ausgefüllte PDF mit Hilfe des vorbereiteten Abgabeordners in ILIAS hoch.

